

Beyond Credential Theft: Infostealers, SaaS Compromise, and AI-Orchestrated Intrusion Campaigns

April 2026 | Brianna Wandt | v1.0

1.0 Executive Summary	4
2.0 Evolution and Technical Mechanisms of Modern Infostealers	5
2.1 From Credential Theft to Identity-Centric Intrusion	5
2.2 Core Malware Families and Tradecraft	6
2.3 Threat Actor Ecosystem and Operational Alignment	8
3.0 Delivery Techniques and Social Engineering	10
3.1 Phishing and Fake Verification Interfaces	10
3.2 ClickFix and Fake Verification Campaigns	10
3.3 Multi-Platform Delivery and Identity Interception	11
3.4 Compromised Websites and Drive-By Delivery	12
3.5 Delivery Methods: Technical Obfuscation and Social Engineering	12
3.6 Malvertising and Trojanized Software	13
4.0 The AI-Enabled Cloud Intrusion Lifecycle	14
4.1 Phase 1 — Reconnaissance and Initial Access	14
4.2 Phase 2 — Validation and Persistence	14
4.3 Phase 3 — AI-Assisted Reconnaissance and Intrusion Operations	15
4.4 Phase 4 — Lateral Movement and Scaling	15
4.5 Phase 5 — Impact, Monetization, and Exfiltration	15
Summary Table: Human vs. Non-Human Identity Attacks	16
4.6 End-to-End Operational Attack Chain	16
5.0 Non-Human Identities and Identity Replay in Cloud Environments	17
5.1 Defining Non-Human Identities (NHIs)	18
5.2 Why Attackers Target NHIs	18
5.2.1 Operational Abuse of Non-Human Identities	19
5.3 OAuth Abuse and Persistent Access	19
5.4 The Limitations of Traditional MFA-Centric Security Models	20
5.5 Identity Replay and the Cloud Pivot	20
5.6 Mechanics of Cloud Service Hijacking	21
5.7 From Low-Privilege Access to Cloud-Wide Compromise	22
6.0 Weaponizing the AI Developer Toolchain	23
6.1 The MCP Security Boundary	24
7.0 Adversary Adoption of Agentic AI and Automation	25
7.1 AI-Enabled Offensive Tradecraft	25
7.1.1 AI-Enhanced Social Engineering and Identity Deception	26

7.1.2 Adaptive Malware and Dynamic Payload Generation	27
7.2 AI-Assisted Intrusion Operations	28
7.3 Automation, Scaling, and Cloud-Native Abuse	28
7.4 Generative AI vs. Agentic AI in Intrusion Operations	29
8.0 Real-World Incident Analysis	30
8.1 The Snowflake Data Breach (2024)	30
8.2 Vercel and Context.ai Compromise (2026)	31
8.3 Storm-2139 and AI Abuse Infrastructure	31
8.4 Rapid AWS Privilege Escalation and LLMjacking Operations	32
8.5 Storm-2139 and AI Abuse Infrastructure	33
8.6 Polyfill.io and DPRK Operational Exposure	33
8.7 Hugging Face Typosquatting and ValleyRAT	34
8.8 Lessons Learned from Modern Infostealer-Enabled Intrusions	34
9.0 The Underground Economy and Monetization	35
9.1 Credential Markets and Access Brokerage	35
9.2 LLMjacking and AI Compute Theft	37
9.3 Cloud-Native Abuse and Infrastructure Monetization	38
9.4 Financial and Operational Impact	38
10.0 Industry Impact and Sector Exposure	39
Industry Sector	39
Observed Impact	39
Primary Operational Risk	39
Manufacturing	40
High ransomware and extortion exposure	40
Low tolerance for operational downtime	40
Healthcare	40
High breach severity and recovery costs	40
Patient-data theft and operational disruption	40
Technology	40
Frequent supply-chain targeting	40
Developer credential theft and SaaS compromise	40
Finance / BFSI	40
High credential and identity targeting	40
SSO abuse and financial fraud	40
10.1 Manufacturing Sector	40
10.2 Healthcare Sector	41
10.3 Technology Sector	41
10.4 Financial Services and BFSI	42
11.0 Detection, Monitoring, and Mitigation Strategies	42
11.1 MITRE ATT&CK Mapping	4
	44

11.2 Behavioral Detection Strategies	44
11.3 Identity and Cloud Security Controls	45
11.4 AI and Developer Toolchain Hardening	45
11.5 Financial and Operational Guardrails	46
11.6 Security Awareness, Human Risk, and Social Engineering Resilience	46
11.7 Early Detection and Proactive Infostealer Response	48
12.0 Threat Evolution and Outlook	49
12.1 The Shift Toward Identity-Centric Intrusions	50
12.2 AI as an Operational Force Multiplier	50
12.3 The Expansion of Cloud and SaaS Attack Surfaces	51
12.4 The Future of Enterprise Defense	51
12.5 Emerging Industry Targeting Trends	51
13.0 Conclusion	52
References	55
Works cited	56

1.0 Executive Summary

The contemporary cyber threat landscape is increasingly defined by identity theft, cloud compromise, and the weaponization of artificial intelligence. Information-stealing malware (“infostealers”) has evolved into a foundational component of the modern cybercrime economy, with recent research identifying large-scale credential theft, cloud identity abuse, and SaaS compromise as major operational trends across both financially motivated and state-aligned intrusion campaigns [1][2][3].

Driven by the Malware-as-a-Service (MaaS) ecosystem, modern infostealers are now designed to harvest high-value identity artifacts such as AI API keys, OAuth tokens, session cookies, cloud credentials, and other non-human identities (NHIs) stored on enterprise systems.

Rather than repeatedly exploiting vulnerabilities inside cloud environments, attackers increasingly compromise a single endpoint and reuse stolen tokens, cookies, and service-account credentials to gain direct access to SaaS platforms, cloud control planes, and AI services. This identity replay model enables rapid lateral movement, persistent access, data exfiltration, and “LLMjacking” operations in which stolen AI credentials are abused for unauthorized inference, compute theft, and resale on underground marketplaces.

At the same time, infostealer delivery techniques have become more sophisticated and deceptive. Modern campaigns rely heavily on malvertising, trojanized software, malicious browser and IDE extensions, and fake verification interfaces such as ClickFix campaigns, where attackers abuse CAPTCHA-style prompts to trick users into executing malicious commands. These campaigns increasingly target developers, contractors, and privileged enterprise users whose systems contain cloud, AI, and CI/CD secrets.

This report examines how infostealers have evolved into a primary enabler of cloud-native intrusion, non-human identity abuse, and AI-driven cybercrime, and explores the operational, financial, and security implications for modern enterprises.

2.0 Evolution and Technical Mechanisms of Modern Infostealers

Infostealers have evolved from malware families focused primarily on consumer credential theft into broader identity-harvesting platforms used across cybercrime, cloud compromise, and AI-enabled intrusion operations. Early infostealer campaigns commonly targeted banking credentials, stored browser passwords, cryptocurrency wallets, and personal account access. In contrast, modern infostealers increasingly prioritize reusable authentication artifacts capable of enabling access to enterprise SaaS platforms, cloud environments, developer tooling, and AI infrastructure.

The growth of Malware-as-a-Service (MaaS) ecosystems has significantly lowered the barrier to entry for credential-theft operations by providing affiliates with modular malware frameworks, payload builders, and operational infrastructure through subscription-based criminal marketplaces [2][5].

These ecosystems lower the barrier to entry for cybercriminal operations while enabling rapid adaptation of delivery techniques, payload obfuscation methods, and credential-harvesting capabilities.

Modern infostealers are increasingly designed to harvest high-value enterprise identity artifacts such as session cookies, OAuth refresh tokens, cloud CLI credentials, Kubernetes configurations, browser authentication databases, CI/CD secrets, AI API keys, and other non-human identities (NHIs). Rather than functioning solely as standalone credential-theft malware, these tools now frequently serve as the initial access layer for broader cloud-native intrusion campaigns involving identity replay, SaaS compromise, cloud-service abuse, and AI-enabled operational workflows.

The operational objective of many contemporary campaigns is no longer limited to endpoint infection itself, but instead focuses on harvesting reusable trust relationships that can be replayed into enterprise systems using legitimate authentication workflows. As organizations increasingly adopt cloud-native infrastructure, AI-enabled tooling, SaaS integrations, and interconnected automation platforms, the value of reusable authentication artifacts has significantly increased within both cybercriminal and state-aligned intrusion operations.

2.1 From Credential Theft to Identity-Centric Intrusion

Historically, infostealer malware focused heavily on browser-stored usernames and passwords associated with consumer banking platforms, email providers, gaming

services, and cryptocurrency wallets. Early campaigns typically emphasized direct financial fraud, account takeover, or resale of stolen credentials on underground marketplaces.

Modern infostealers increasingly prioritize reusable authentication artifacts such as session cookies, OAuth refresh tokens, cloud CLI credentials, and AI API keys rather than traditional browser passwords alone. Recent research suggests a broader shift toward identity-centric intrusion operations targeting SaaS platforms, cloud-native environments, and developer ecosystems [1][2][3][61].

Recent campaigns increasingly target enterprise authentication artifacts capable of enabling access across cloud and SaaS ecosystems. Common targets now include OAuth tokens, browser session cookies, cloud API keys, AWS and Azure CLI credentials, GitHub tokens, Kubernetes configurations, SSH keys, CI/CD secrets, .env files, and AI service credentials associated with platforms such as OpenAI, Anthropic, Gemini, and Azure OpenAI.

This shift reflects a broader transition from endpoint-centric compromise toward identity-centric intrusion operations. In many cases, the compromised endpoint itself is no longer the primary objective. Instead, attackers focus on harvesting reusable authentication material already trusted by enterprise systems and cloud services.

Modern attackers increasingly avoid repeated interaction with authentication systems by replaying previously authenticated sessions, OAuth grants, and machine identities directly into SaaS platforms, cloud control planes, and AI-enabled services. This operational model reduces reliance on noisy exploitation techniques while enabling attackers to blend malicious activity into otherwise legitimate cloud and API traffic.

The increasing adoption of cloud-native architecture, SaaS applications, AI-enabled workflows, and interconnected automation platforms has further amplified the importance of identity compromise within modern intrusion operations. In environments where applications, APIs, and machine identities continuously exchange authentication material, compromise of a single endpoint may provide indirect access to multiple downstream systems through delegated trust relationships and persistent authentication workflows.

2.2 Core Malware Families and Tradecraft

The industrialization of modern infostealer campaigns has been driven largely by MaaS ecosystems that provide modular malware frameworks, payload builders, credential marketplaces, and affiliate distribution networks. Contemporary malware families increasingly

prioritize stealth, credential harvesting, identity replay, and cloud access rather than disruptive endpoint activity alone.

Malware Family	Primary Tactics and Stealth Mechanisms	Evolution and Operational Context
Lumma (LummaC2)	Direct syscalls, process hollowing, Telegram/Steam C2 fallback, ClickFix delivery workflows	One of the most prevalent info stealers observed in 2024–2025 campaigns
EDDIESTEALER	Rust-based payloads, XOR string encryption, stripped symbols, self-deletion techniques	Focuses heavily on Chromium credential theft and browser-session compromise
StealC / StealC V2	Modular architecture, JSON-based C2 communications, multi-monitor screenshot capture	Expanded targeting toward cloud credentials, .env files, and AI API keys
LameHug	Python-based malware integrating LLM-generated runtime command execution	Early example of AI-assisted malware execution and adaptive payload generation

Modern info stealers increasingly incorporate advanced obfuscation and anti-analysis techniques designed to evade traditional endpoint detection systems. Common capabilities include encrypted configuration files, dynamically generated payloads, in-memory execution, sandbox evasion, process hollowing, and the use of legitimate cloud services or messaging platforms for command-and-control communication.

Many malware families also prioritize browser-session theft over traditional password extraction alone. Rather than cracking credentials directly, info stealers frequently harvest authenticated session cookies and browser tokens after users have already completed MFA workflows. This allows attackers to replay authenticated sessions directly into cloud platforms, SaaS environments, and enterprise applications without triggering additional login verification challenges.

Recent malware evolution additionally reflects the growing convergence between info stealers,

AI tooling, and cloud-native infrastructure. Some campaigns increasingly target AI development ecosystems, browser extensions, open-source repositories, and developer tooling environments that contain high-value machine identities, API credentials, and cloud-access material capable of enabling downstream enterprise compromise.

Collectively, these developments demonstrate how modern infostealers have evolved into flexible identity-harvesting platforms that support credential theft, cloud compromise, SaaS intrusion, AI abuse, and large-scale access brokerage operations across interconnected enterprise environments.

2.3 Threat Actor Ecosystem and Operational Alignment

Modern infostealer operations are supported by a diverse threat ecosystem that includes financially motivated cybercriminal organizations, Malware-as-a-Service (MaaS) operators, initial-access brokers (IABs), and state-aligned threat actors. Although these groups differ in operational objectives, they increasingly rely on overlapping malware families, credential marketplaces, cloud-focused intrusion techniques, and identity-centric attack workflows.

The growth of MaaS ecosystems has significantly lowered the barrier to entry for credential-theft operations. Malware developers increasingly maintain modular infostealer platforms that affiliates distribute through phishing campaigns, malvertising, fake verification interfaces, software piracy sites, and compromised developer tooling. In many cases, malware developers do not conduct intrusion operations directly, but instead monetize subscription access to malware frameworks, credential logs, and command-and-control infrastructure used by downstream affiliates.

Financially motivated cybercriminal groups frequently use infostealers as the initial access layer for ransomware deployment, SaaS compromise, business email compromise (BEC), and cloud extortion campaigns. Groups associated with LummaC2, StealC, RedLine, and related malware ecosystems increasingly target browser sessions, OAuth tokens, cloud credentials, and developer environments capable of enabling broader enterprise compromise.

Initial-access brokers (IABs) also play a significant role within modern intrusion ecosystems. These actors specialize in acquiring, validating, and reselling compromised credentials, VPN access, SaaS sessions, cloud identities, and enterprise authentication material harvested through infostealer infections. Rather than conducting ransomware or extortion operations themselves, IABs frequently sell validated access to ransomware affiliates, financially motivated threat groups, and state-aligned operators.

Recent research additionally demonstrates growing overlap between cybercriminal

tooling and state-aligned intrusion activity. Threat actors associated with APT28, DPRK-affiliated operations, and other state-linked campaigns have increasingly incorporated infostealer malware, cloud identity abuse, AI-enabled tooling, and SaaS compromise techniques into operational workflows. In several reported cases, state-aligned operators used credential-stealing malware, synthetic identities, and AI-assisted tooling to support espionage, supply-chain compromise, or insider-access operations targeting enterprise environments.

This convergence between cybercrime ecosystems and state-aligned operations reflects a broader shift in the threat landscape. Modern intrusion campaigns increasingly rely on shared credential marketplaces, reusable identity artifacts, cloud-native operational workflows, and overlapping malware ecosystems that blur traditional distinctions between financially motivated cybercrime and state-sponsored activity.

Threat Ecosystem	Common Objectives	Associated Techniques and Malware
Malware-as-a-Service (MaaS) Operators	Credential theft and malware distribution	LummaC2, StealC, EDDIESTEALER, ClickFix delivery
Initial-Access Brokers (IABs)	Sale of enterprise access and cloud identities	Session replay, VPN access resale, OAuth token abuse
Financially Motivated Threat Groups	Ransomware, extortion, SaaS compromise	Infostealer-enabled cloud pivoting and credential replay
State-Aligned Threat Actors	Espionage, supply-chain compromise, persistence	AI-assisted intrusion workflows, synthetic identities, cloud abuse
DPRK-Linked Operations	Insider access, financial theft, operational infiltration	Remote-worker fraud, credential theft, supply-chain abuse

3.0 Delivery Techniques and Social Engineering

Modern infostealer operations rely heavily on social engineering, trusted-platform abuse, and technical obfuscation to bypass traditional security controls. Rather than exploiting vulnerabilities directly, many campaigns manipulate users into executing malicious payloads through phishing emails, fake verification interfaces, trojanized software, compromised websites, and malvertising campaigns. Increasingly, these techniques are designed not only to infect endpoints, but also to harvest reusable identity artifacts that allow attackers to replay authenticated access into SaaS platforms, cloud control planes, and AI services. ¹⁵.

3.1 Phishing and Fake Verification Interfaces

Phishing remains one of the most common delivery mechanisms for infostealers, particularly when combined with fake verification interfaces such as ClickFix-style CAPTCHA lures. Attackers commonly distribute emails themed around invoices, document-sharing requests, account notifications, or collaboration platforms that redirect victims to attacker-controlled landing pages. These pages often imitate legitimate Cloudflare Turnstile or Google reCAPTCHA interfaces and prompt users to “verify” themselves before proceeding. In many campaigns, the verification prompt serves as a social-engineering mechanism rather than a traditional CAPTCHA challenge. Microsoft and Elastic Security Labs documented campaigns in which malicious JavaScript used functions such as `navigator.clipboard.writeText()` or `document.execCommand("copy")` to silently place obfuscated PowerShell commands into the victim’s clipboard. Victims were then instructed to paste the command into the Windows Run dialog, PowerShell, or Terminal, resulting in user-assisted malware execution. Industry reporting further reflects the scale of this trend. IBM X-Force reported an 84% increase in phishing emails delivering infostealers year-over-year, with researchers attributing much of the growth to AI-assisted phishing automation [100][101].

3.2 ClickFix and Fake Verification Campaigns

Threat actors increasingly abuse trusted CAPTCHA and verification workflows to deliver infostealers through user-assisted execution techniques commonly referred to as ClickFix campaigns. These operations use fraudulent verification interfaces that trick users into executing malicious commands manually through PowerShell, Windows Run dialogs, or terminal applications. Many campaigns rely on “pastejacking,” in which embedded JavaScript silently copies obfuscated commands into the victim’s clipboard before instructing the user to paste and execute them locally. Researchers have also

observed CAPTCHA-gated phishing infrastructure, fake crash-repair prompts (“CrashFix”), and malicious update workflows (“FileFix”) designed to evade automated scanning systems while increasing the likelihood of user execution. Recent reporting suggests these techniques have become increasingly industrialized through builder services that provide customizable lures, multilingual templates, and scalable payload-delivery workflows for affiliates [7][8][102][103][104].

3.3 Multi-Platform Delivery and Identity Interception

Modern infostealer campaigns increasingly operate across Windows, macOS, and Linux environments, adapting payload delivery and credential-harvesting techniques based on the victim’s operating system and authentication workflows. Many campaigns use JavaScript-based fingerprinting to identify the target platform and dynamically deliver tailored commands, scripts, or payloads designed to maximize credential theft and user-assisted execution success rates.

On Windows systems, campaigns commonly rely on PowerShell, Windows Run dialogs, and LOLBins to execute obfuscated payloads, while macOS-focused variants increasingly abuse Terminal workflows, `dscl` password validation, and Keychain access to harvest credentials and session material. This cross-platform evolution reflects a broader shift toward identity-centric compromise, where attackers prioritize reusable authentication artifacts and cloud access over disruptive malware execution alone.

Arrival Vector	Technical Mechanism	Operational Objective
AITM Phishing	Reverse-proxy frameworks such as Tycoon 2FA intercept session tokens and authentication flows in real time.	Enables session replay and MFA bypass for SaaS and cloud platforms.
ConsentFix	Users are socially engineered into authorizing malicious OAuth applications with persistent API permissions.	Establishes long-term access to SaaS, cloud, and AI services even after password resets.

Malvertising	Poisoned advertisements redirect users to cloned software portals and trojanized downloads.	Targets developers and enterprise users likely to store cloud credentials and API keys locally.
Vishing	Attackers impersonate IT or support personnel and guide victims through executing “diagnostic” commands.	Bypasses technical controls through direct human manipulation and user-assisted execution.

3.4 Compromised Websites and Drive-By Delivery

Compromised websites remain a major delivery vector for modern infostealer campaigns. Elastic Security Labs documented EDDIESTEALER, a Rust-based infostealer distributed through attacker-controlled websites displaying fraudulent verification interfaces designed to mimic legitimate CAPTCHA workflows. In these campaigns, obfuscated JavaScript payloads manipulated clipboard contents and guided users through executing malicious PowerShell commands that deployed the malware silently in the background.

Similar tactics have been observed across LummaC2, Aurora, and other MaaS ecosystems, where attackers inject malicious JavaScript into trusted websites, create cloned download portals, or distribute drive-by scripts designed to deploy credential stealers and harvest cloud identity artifacts. These campaigns increasingly target developers and enterprise users whose systems contain cloud credentials, AI API keys, browser session cookies, and CI/CD secrets

3.5 Delivery Methods: Technical Obfuscation and Social Engineering

Modern infostealer campaigns rely on a combination of social engineering, trusted-platform abuse, and technical obfuscation to deliver malicious payloads and harvest identity artifacts from compromised systems. Rather than relying solely on traditional malware delivery methods, attackers increasingly use phishing lures, fake verification interfaces, compromised websites, trojanized software, and malvertising campaigns to manipulate users into executing malware themselves. These techniques are designed to bypass conventional security controls by exploiting user trust and

blending malicious activity with legitimate web and application behavior.

Contemporary infostealers prioritize stealth, persistence, and identity theft over disruptive behavior, often remaining undetected on infected systems for extended periods. Research has shown that a significant percentage of compromised devices were running fully updated antivirus solutions at the time of infection, highlighting the limitations of traditional signature-based defenses against user-assisted execution and obfuscated payload delivery.

Although the initial compromise occurs on the endpoint, the operational objective of many modern infostealer campaigns is access to cloud and SaaS environments. Current malware families routinely harvest reusable identity artifacts, including cloud access tokens, OAuth refresh tokens, API keys, browser session cookies, cloud CLI credentials, and other non-human identities (NHIs). Once exfiltrated, these artifacts allow attackers to replay authenticated access directly into cloud platforms and AI services, often bypassing multi-factor authentication (MFA) controls entirely. As a result, a single interaction with a fake verification interface or malicious download can rapidly escalate into unauthorized access across enterprise cloud environments, SaaS platforms, and AI infrastructure.

3.6 Malvertising and Trojanized Software

Malvertising has emerged as another critical delivery vector for infostealers, particularly in campaigns targeting developers and enterprise users. Threat actors increasingly purchase poisoned advertisements for legitimate software, developer tools, browser utilities, and AI applications, redirecting victims to cloned download sites that distribute malware such as Lumma or StealC. In one documented campaign, researchers identified a malicious executable named `notiom.exe` masquerading as the legitimate Notion productivity application.

These campaigns are particularly effective because they target users actively searching for trusted software or AI-related tools, often on systems containing cloud CLI credentials, browser authentication tokens, package-publishing secrets, and other high-value non-human identities. Unlike traditional phishing, malvertising campaigns frequently bypass email security controls entirely and exploit trust in search engines, advertisements, and widely recognized platforms.

Collectively, these techniques demonstrate how modern infostealer operations increasingly combine social engineering, identity interception, and platform-specific delivery mechanisms to maximize credential theft and cloud access. Rather than relying solely on malware execution, attackers increasingly prioritize the theft and replay of

authentication artifacts that provide persistent access to enterprise SaaS platforms, cloud control planes, and AI infrastructure.

4.0 The AI-Enabled Cloud Intrusion Lifecycle

Modern infostealer campaigns increasingly function as the first stage of broader identity-centric cloud intrusions. Rather than focusing solely on endpoint compromise, attackers use stolen identity artifacts, non-human identities (NHIs), and AI-enabled tooling to move rapidly from local infection to persistent access across SaaS platforms, cloud control planes, and enterprise AI environments.

4.1 Phase 1 — Reconnaissance and Initial Access

Initial access commonly begins through phishing campaigns, fake verification interfaces, trojanized software, malvertising, or compromised developer tools. Once executed, modern infostealers scan infected systems for reusable identity artifacts rather than traditional credentials alone. Common targets include browser session cookies, OAuth tokens, cloud CLI credentials, .env files, SSH keys, AI API keys, Kubernetes configurations, and service-account material associated with AWS, Azure, GCP, OpenAI, and Anthropic environments.

Attackers increasingly prioritize non-human identities because these credentials often provide direct programmatic access to cloud resources without requiring repeated MFA challenges. In many cases, possession of a valid cloud access token or API key effectively grants immediate authenticated access to enterprise infrastructure.

4.2 Phase 2 — Validation and Persistence

Following exfiltration to command-and-control (C2) infrastructure, stolen credentials and tokens are typically validated automatically within minutes. Security research has shown that exposed cloud credentials are frequently tested against cloud-provider APIs shortly after compromise, allowing attackers to rapidly identify high-value accounts, active tokens, and privileged service identities.

Persistence is often established through OAuth abuse and identity expansion techniques. In “ConsentFix”-style operations, victims are socially engineered into authorizing malicious OAuth applications that retain persistent API access even after password resets or endpoint remediation. Attackers may also target Model Context Protocol (MCP) servers, CI/CD systems, and automation platforms that provide indirect access to internal enterprise data and AI workflows.

4.3 Phase 3 — AI-Assisted Reconnaissance and Intrusion Operations

Emerging campaigns increasingly incorporate AI-assisted tooling and automation into post-compromise operations. Rather than conducting all reconnaissance manually, attackers may abuse compromised AI agents, developer-assistant platforms, or orchestration tooling already integrated into enterprise workflows. Compromised AI agents and automation frameworks may be leveraged

be leveraged to enumerate internal documentation platforms, cloud resources, source-code repositories, and collaboration systems in order to identify sensitive data, privileged accounts, exposed secrets, and additional attack paths. Researchers have also warned that AI-assisted analysis may accelerate vulnerability discovery, misconfiguration identification, and privilege-escalation workflows within compromised environments. [51] [98] [101]

4.4 Phase 4 — Lateral Movement and Scaling

The abuse of non-human identities enables attackers to operate through legitimate cloud and AI infrastructure while minimizing traditional detection indicators. Because activity originates from authorized service accounts, OAuth applications, or AI-integrated workflows, malicious actions may appear operationally legitimate to conventional monitoring systems. At this stage, attackers commonly expand access through cloud IAM modifications, service-account creation, token generation, and SaaS integration abuse. AI-enabled automation may also accelerate large-scale data discovery and exfiltration by summarizing sensitive documents, querying enterprise datasets, or automating reconnaissance tasks that previously required significant manual effort.

4.5 Phase 5 — Impact, Monetization, and Exfiltration

The final stage of modern infostealer-enabled intrusions increasingly centers on cloud monetization, data theft, and operational persistence rather than ransomware alone. Stolen AI API keys and cloud credentials are frequently abused for unauthorized inference operations, large-scale compute theft, spam generation, and “LLMjacking” campaigns in which attackers resell or consume AI resources at the victim’s expense. In more advanced scenarios, attackers may achieve broad control over cloud management planes, maintain persistent OAuth access, rotate credentials, deploy additional workloads, or exfiltrate sensitive intellectual property before detection occurs.

The growing convergence between infostealers, cloud identity abuse, and AI infrastructure compromise significantly increases both the operational scale and financial impact of modern intrusions.

Summary Table: Human vs. Non-Human Identity Attacks

Feature	Traditional Intrusions	Modern NHI/AI Intrusions
Primary Target	Employee credentials	API keys, OAuth tokens, NHIs
Authentication	MFA commonly enforced	Token- and service-based access
Speed	Hours to days	Minutes through automation
Persistence	Password reuse or reinfection	OAuth abuse and token replay
Scale	Human-operated activity	Automated cloud enumeration
Detection	User-behavior anomalies	Blends into SaaS and AI traffic
Primary Objective	Credential theft and ransomware	Cloud access, AI abuse, data theft

4.6 End-to-End Operational Attack Chain

Modern infostealer-enabled intrusion campaigns increasingly follow a repeatable operational sequence centered on identity compromise, cloud access, and reuse of trusted authentication workflows. Although individual techniques vary across threat actors and environments, most campaigns follow a common progression that begins with user-assisted malware delivery and expands into broader cloud-native compromise operations.

Initial access frequently occurs through phishing campaigns, fake verification interfaces, trojanized software, malicious browser extensions, or compromised developer tooling. Once executed, infostealers harvest browser session cookies, OAuth tokens, API keys, cloud CLI credentials, .env files, SaaS authentication material, and other reusable identity artifacts stored on the compromised endpoint.

Following exfiltration, attackers rapidly validate stolen credentials using automated infrastructure capable of testing cloud access, SaaS integrations, VPN credentials, and AI API keys within minutes of compromise. Rather than repeatedly bypassing authentication controls, attackers increasingly replay authenticated sessions, OAuth grants, and machine identities directly into cloud platforms and SaaS environments using legitimate service workflows.

Once cloud access is established, attackers commonly expand access through delegated authentication abuse, OAuth persistence, service-account creation, cloud enumeration, and identity chaining across interconnected SaaS platforms and development environments. Even low-privilege user accounts may provide indirect access to sensitive infrastructure through shared cloud integrations, CI/CD pipelines, internal documentation systems, and AI-connected operational tooling.

Modern campaigns increasingly incorporate AI-assisted tooling and automation into post-compromise activity. Threat actors may use AI-enabled systems to automate reconnaissance, summarize internal data, generate phishing content, analyze repositories, or accelerate cloud-native operational workflows while blending into otherwise legitimate SaaS and API activity.

The final stages of these operations increasingly focus on monetization through ransomware deployment, extortion, cloud-service abuse, credential resale, AI compute theft, LLMjacking, or downstream access brokerage. In many cases, the operational objective is no longer endpoint disruption alone, but persistent access to reusable trust relationships capable of supporting long-duration cloud and SaaS compromise.

5.0 Non-Human Identities and Identity Replay in Cloud Environments

Modern infostealer campaigns increasingly target non-human identities (NHIs) and reusable authentication artifacts as a primary mechanism for accessing enterprise cloud, SaaS, and AI environments. Rather than focusing exclusively on traditional usernames and passwords, attackers now prioritize API keys, OAuth refresh tokens, service accounts, cloud CLI credentials, Kubernetes identities, CI/CD secrets, browser session cookies, and machine-to-machine authentication material that provide direct programmatic access to enterprise infrastructure. This shift reflects a broader evolution from endpoint-centric compromise toward identity-centric intrusion operations designed to exploit trusted authentication workflows rather than repeatedly bypassing security controls.

5.1 Defining Non-Human Identities (NHIs)

Non-human identities refer to digital identities used by applications, cloud workloads, automation platforms, APIs, AI agents, and enterprise services to authenticate and interact with other systems. Common examples include cloud service accounts, managed identities, OAuth applications, AI API keys, Kubernetes service accounts, CI/CD pipeline credentials, SSH keys, and machine-to-machine OAuth grants.

Unlike traditional user accounts, these identities are frequently embedded within scripts, development environments, cloud configuration files, browser sessions, and automation tooling. In many enterprise environments, NHIs possess elevated privileges, broad API access, and persistent authentication capabilities that make them highly attractive targets for attackers. Because these identities are often difficult to inventory and monitor consistently, organizations may lack visibility into where credentials are stored, how they are used, or whether they have been exposed through malware infections or supply-chain compromise.

5.2 Why Attackers Target NHIs

Threat actors increasingly prioritize NHIs because they provide operational advantages that traditional user credentials often cannot. Many non-human identities rely on long-lived credentials, reusable tokens, or machine-based authentication workflows that are not consistently protected by multi-factor authentication (MFA) or interactive user verification. As a result, possession of a valid API key, OAuth token, or cloud service credential may grant immediate authenticated access to enterprise environments without requiring repeated authentication challenges.

Modern infostealers routinely scan infected systems for reusable identity artifacts associated with cloud and AI platforms. Common targets include .env files, browser session cookies, AWS and Azure CLI credentials, Kubernetes configurations, GitHub tokens, Docker authentication material, OpenAI API keys, and OAuth refresh tokens tied to SaaS platforms. Security research has shown that exposed cloud credentials are frequently validated automatically within minutes of compromise using cloud-provider APIs and automated credential-checking infrastructure.

These identities also support operational persistence. In OAuth-based attacks, victims may unknowingly authorize malicious applications that retain persistent API access even after passwords are changed or endpoints are remediated. This form of identity persistence allows attackers to maintain long-term access to SaaS platforms, cloud environments, and AI-integrated workflows while reducing reliance on traditional malware execution.

5.2.1 Operational Abuse of Non-Human Identities

Modern intrusion campaigns increasingly rely on compromised non-human identities (NHIs), service accounts, OAuth applications, cloud automation workflows, and AI-connected agents to conduct malicious operations at scale. Unlike traditional attacks dependent on direct interactive access by human operators, NHI-enabled attacks frequently leverage machine-authenticated workflows capable of operating continuously across cloud and SaaS environments.

Threat actors commonly weaponize compromised API keys, OAuth tokens, CI/CD credentials, Kubernetes service accounts, and cloud automation identities to perform reconnaissance, deploy workloads, query APIs, exfiltrate data, and interact with enterprise systems through otherwise legitimate service workflows [19][41][61]. Because these identities frequently operate without interactive login prompts or traditional MFA enforcement, attackers may maintain persistent access while blending malicious activity into normal cloud and automation traffic.

Researchers have also observed increasing abuse of AI-connected orchestration platforms, automation frameworks, and agentic AI systems capable of interacting with enterprise services autonomously through delegated authentication mechanisms [51][61]. In these environments, compromised AI agents or orchestration platforms may function as operational force multipliers that automate reconnaissance, data collection, cloud enumeration, phishing generation, and lateral movement across interconnected SaaS ecosystems.

Rather than relying exclusively on disruptive malware execution, attackers increasingly operate through trusted machine identities, authorized APIs, and cloud-native automation workflows that reduce operational visibility and support scalable intrusion activity across distributed enterprise environments [3][19][41][61].

5.3 OAuth Abuse and Persistent Access

OAuth abuse has emerged as a major persistence mechanism in cloud and SaaS compromise operations. In these attacks, users are socially engineered into authorizing malicious OAuth applications that request extensive API permissions to enterprise services, cloud platforms, or AI-enabled workflows. Once granted, these permissions often remain active independently of the user's password, allowing attackers to maintain access even after password resets or endpoint remediation efforts.

This technique, sometimes referred to as "ConsentFix," enables attackers to establish long-lived access to cloud-connected applications, collaboration platforms, email

systems, and AI-integrated tooling while blending into otherwise legitimate API activity. Because OAuth applications frequently operate through trusted service workflows, malicious activity may generate fewer traditional indicators of compromise than conventional malware operations.

The growing adoption of AI agents, automation platforms, and cloud-native integrations further increases the potential impact of OAuth abuse. Many enterprise systems now rely on interconnected APIs and delegated authentication workflows that aggregate access across multiple platforms simultaneously. As a result, compromise of a single OAuth application or service account may expose large portions of an organization's cloud and SaaS ecosystem.

5.4 The Limitations of Traditional MFA-Centric Security Models

The rise of identity replay and non-human identity abuse has exposed important limitations in traditional MFA-centric security models. While MFA remains highly effective against many forms of credential theft, it is often less effective against attacks involving stolen session tokens, OAuth grants, browser cookies, and machine identities that have already completed authentication workflows.

Modern attackers increasingly avoid interacting directly with MFA challenges altogether. Instead, they prioritize the theft of authenticated sessions and reusable tokens that inherit the trust relationships already established by legitimate users and services. In cloud-native environments where applications, APIs, and automation frameworks continuously exchange authentication material, compromise of a single endpoint may rapidly expand into broader enterprise access through trusted machine-to-machine workflows.

This evolution reflects a broader shift in enterprise threat models. The primary objective of many modern intrusions is no longer simply credential theft, but the acquisition and replay of identity artifacts that enable persistent access across interconnected cloud, SaaS, and AI ecosystems.

5.5 Identity Replay and the Cloud Pivot

The cloud pivot in modern infostealer operations increasingly centers on session replay and authenticated access abuse rather than direct exploitation of cloud infrastructure. Once authentication material is harvested from a compromised endpoint, attackers may replay those credentials directly into SaaS applications, cloud management platforms, developer environments, and AI services using legitimate authentication workflows [6][19][41].

Session cookies and OAuth tokens are particularly valuable because they may allow attackers to inherit previously authenticated sessions without repeatedly triggering MFA challenges. Modern infostealers frequently target browser authentication databases, OAuth refresh tokens, and SaaS session material capable of granting access after a user has already authenticated successfully [6][19][41].

Many infostealers also search for cloud CLI credentials, API keys, SSH configurations, Kubernetes tokens, and locally stored developer secrets associated with AWS, Azure, GCP, GitHub, Docker, and CI/CD environments. Files such as `~/.aws/credentials`, Azure token caches, and `.env` configurations may provide attackers with direct programmatic access to enterprise systems and development infrastructure [1][3][61].

Rather than relying heavily on repeated exploitation or destructive malware deployment, attackers increasingly focus on abusing trusted authentication pathways already embedded within SaaS ecosystems and enterprise cloud services. Once access is established, threat actors may enumerate resources, create additional service accounts, generate new API keys, or expand OAuth permissions to strengthen persistence and broaden access across interconnected platforms [19][41][61].

Researchers increasingly note that these techniques may reduce visibility for traditional perimeter-focused detection systems because malicious activity frequently originates from otherwise valid sessions, authorized API calls, and trusted authentication flows rather than overt malware execution alone [2][6][41].

5.6 Mechanics of Cloud Service Hijacking

Modern infostealer campaigns increasingly leverage stolen authentication material to conduct cloud-focused intrusion operations through legitimate service workflows and delegated authentication mechanisms. Rather than exploiting vulnerabilities directly within cloud infrastructure, attackers frequently abuse reusable credentials harvested from compromised endpoints to gain authenticated access to enterprise SaaS platforms, cloud management interfaces, developer environments, and AI-enabled services [6][19][41].

One commonly observed technique involves session replay attacks in which stolen browser session cookies are reused to inherit previously authenticated sessions on cloud consoles and web-based SaaS applications. Because these sessions have often already completed multi-factor authentication (MFA) workflows on the victim system, attackers may gain access without triggering additional authentication prompts. Researchers increasingly identify this approach as a major operational component of modern SaaS compromise and cloud-account hijacking campaigns [6][19][41].

Infostealers also routinely target locally stored cloud authentication material associated with AWS, Azure, and GCP environments. Common targets include files such as `~/.aws/credentials`, Azure token caches, Kubernetes configurations, developer-environment secrets, and service-account credentials capable of providing direct programmatic access to cloud APIs and enterprise infrastructure [1][3][61]. Long-lived access keys and machine-authenticated service accounts are particularly valuable because they may support persistent API access and automated cloud operations at scale.

OAuth tokens and delegated SaaS integrations further expand the operational reach of these attacks. Threat actors increasingly target SaaS providers, third-party integrations, and OAuth-connected applications to harvest long-lived authentication tokens that function as persistent access bridges across interconnected cloud environments. Once obtained, these tokens may allow attackers to move laterally between collaboration platforms, cloud-management systems, development environments, and AI-connected services using otherwise legitimate API activity and trusted enterprise workflows [19][41][61].

Researchers have also documented intrusion activity involving groups such as Storm-0501, which reportedly specialized in compromising hybrid identity infrastructure and directory-synchronization environments associated with Microsoft Entra Connect deployments. These operations demonstrated how attackers may pivot from compromised endpoints into broader cloud-administration workflows by abusing synchronization credentials, delegated trust relationships, and enterprise identity-management infrastructure [3][19].

5.7 From Low-Privilege Access to Cloud-Wide Compromise

Modern infostealer campaigns do not necessarily require compromise of highly privileged accounts in order to produce significant operational impact. Research increasingly suggests that seemingly low-privilege enterprise accounts may still provide pathways into broader SaaS ecosystems, cloud-connected services, and internal collaboration environments [3][19][61].

Attackers frequently use compromised accounts to enumerate SaaS integrations, collaboration platforms, internal documentation repositories, and cloud-connected applications associated with the victim organization. Access to enterprise email, messaging systems, developer tooling, or shared knowledge platforms may expose additional credentials, architecture details, API documentation, or operational procedures capable of enabling further compromise [2][19][41].

Developer and technical-user systems are particularly valuable because even non-administrative accounts often contain locally stored secrets, browser sessions, SSH keys, CI/CD credentials, Kubernetes tokens, and source-code access tied to enterprise infrastructure [1][3][61][73]. In many cases, attackers expand access through accumulated credential exposure and inherited trust relationships rather than traditional operating-system privilege-escalation exploits.

Delegated SaaS permissions and cloud-connected workflows further amplify this risk. A compromised account may still possess access to automation frameworks, AI-enabled services, internal APIs, or shared operational platforms capable of exposing additional enterprise functionality. Once attackers gain access to one trusted account, they may progressively move across interconnected services through inherited permissions, persistent sessions, and shared authentication mechanisms [19][41][61].

Threat actors also commonly leverage compromised accounts for internal reconnaissance and phishing expansion. Access to legitimate enterprise communication systems may allow attackers to impersonate trusted personnel, distribute phishing lures internally, or target higher-value users while blending into otherwise routine organizational activity [2][3][100].

In many cloud-focused intrusions, escalation increasingly occurs through chained access across interconnected systems rather than direct exploitation alone. By combining stolen sessions, OAuth grants, cloud API access, internal documentation, and exposed machine credentials, attackers may progressively expand access across SaaS platforms, cloud resources, development pipelines, and AI-connected infrastructure [19][41][61].

6.0 Weaponizing the AI Developer Toolchain

In 2025 and 2026, threat actors increasingly targeted the software supply chains, developer tooling, and AI-integrated workflows associated with modern enterprise environments. As organizations adopted AI coding assistants, browser extensions, Model Context Protocol (MCP) integrations, and cloud-connected development platforms, attackers began exploiting these ecosystems to harvest credentials, access repositories, compromise non-human identities (NHIs), and gain persistent access to enterprise infrastructure. Unlike traditional malware campaigns focused primarily on endpoint disruption, these operations increasingly target developer environments and AI-enabled workflows because they contain high-value identity artifacts, cloud credentials, API keys, OAuth tokens, source code, and direct access to SaaS and cloud infrastructure. This evolution reflects the growing convergence between software supply-chain compromise, cloud identity abuse, and AI-assisted intrusion operations.

6.1 The MCP Security Boundary

The Model Context Protocol (MCP), which enables AI agents to interact with enterprise tools, APIs, databases, and external services, has emerged as a significant security consideration within AI-enabled enterprise environments. MCP infrastructure is increasingly integrated into development workflows, automation platforms, and AI-assisted operational tooling, allowing language models and autonomous agents to access enterprise resources through standardized interfaces and delegated authentication mechanisms.

Because MCP servers frequently broker communication between AI systems and multiple enterprise services simultaneously, compromise of an MCP-connected environment may expose authentication tokens, SaaS integrations, internal APIs, cloud resources, and sensitive operational data. In many implementations, MCP infrastructure aggregates access to platforms such as GitHub, Slack, cloud storage environments, internal databases, CI/CD systems, and enterprise documentation platforms through centralized service workflows.

Researchers have identified growing security concerns surrounding Model Context Protocol (MCP) integrations and AI-connected orchestration workflows, particularly in environments where AI agents aggregate OAuth tokens, SaaS access, and cloud-service permissions across multiple enterprise systems [51]. Security researchers have also documented concerns involving certain MCP SDK implementations and transport-layer architectures, including scenarios in which local commands or subprocesses may execute before complete validation of user-controlled inputs. Although implementation details vary across environments, these architectural patterns may increase the risk of command execution, credential exposure, or unauthorized access when AI-connected services are improperly secured or integrated with overly permissive service accounts [51].

The operational risk associated with MCP environments extends beyond individual endpoint compromise. Once attackers obtain access to an MCP-connected service, orchestration platform, or associated authentication token, they may leverage those trusted integrations to enumerate internal resources, interact with enterprise systems, query sensitive data, or expand access across interconnected cloud and SaaS environments using legitimate service workflows.

As organizations continue integrating AI agents into enterprise operations, MCP-connected architectures increasingly represent a convergence point between AI orchestration, cloud identity systems, SaaS integrations, and non-human identities. This convergence significantly expands the potential impact of identity compromise,

particularly in environments where AI agents possess broad delegated access across multiple enterprise platforms.

7.0 Adversary Adoption of Agentic AI and Automation

Threat actors increasingly incorporate generative AI, cloud-native automation, and AI-assisted operational tooling into modern intrusion campaigns. Rather than relying exclusively on manual reconnaissance, payload development, and post-compromise activity, attackers are leveraging AI-enabled systems to accelerate phishing operations, automate analysis, improve payload variability, and scale cloud-based intrusion workflows across enterprise environments.

This evolution reflects a broader convergence between AI platforms, cloud-native infrastructure, non-human identities (NHIs), and software supply-chain ecosystems. As organizations integrate AI agents, automation frameworks, and cloud-connected orchestration platforms into operational workflows, attackers increasingly exploit those same technologies to reduce operational friction, improve stealth, and expand access across interconnected SaaS and cloud environments.

7.1 AI-Enabled Offensive Tradecraft

Threat actors increasingly use generative AI and large language models (LLMs) to support offensive cyber operations, including phishing, malware development, reconnaissance, and operational automation. Rather than functioning solely as targets for credential theft or cloud abuse, AI systems are increasingly being leveraged as operational tools within modern intrusion campaigns.

Researchers have observed increasing use of generative AI within generative AI into phishing workflows, malware development, and command-generation processes designed to improve payload variability and reduce reliance on static execution logic [33][36][98][101].

One emerging trend involves the integration of LLMs into malware and command-generation workflows to reduce reliance on static payloads and easily identifiable command structures. Researchers analyzing the LameHug infostealer documented the use of the Qwen 2.5-Coder model through the Hugging Face API to dynamically generate system commands during execution. Because command sequences may be generated programmatically at runtime rather than embedded

statically within the malware binary, these approaches may reduce the effectiveness of traditional signature-based detection and static analysis techniques.

AI-assisted malware development may also support greater operational adaptability within compromised environments. Rather than deploying fully static execution logic, emerging malware families may modify command structures, execution patterns, or operational behavior based on the victim environment, available privileges, security tooling, or cloud configurations encountered during execution.

Although many of these techniques remain in relatively early stages of operational maturity, the growing integration of generative AI into offensive tooling reflects a broader shift toward increasingly automated, adaptive, and cloud-aware intrusion operations.

7.1.1 AI-Enhanced Social Engineering and Identity Deception

Threat actors increasingly use generative AI to improve the scale, realism, and effectiveness of social-engineering operations. AI-assisted tooling is now commonly used to generate phishing emails, construct fraudulent websites, automate dialogue interactions, and create synthetic media capable of impersonating trusted individuals or organizations.

Unlike traditional phishing campaigns, AI-generated content frequently lacks the grammatical inconsistencies and formatting anomalies historically associated with malicious communications. Researchers have observed substantial increases in phishing campaigns delivering infostealers and credential-harvesting payloads, with security reporting attributing much of this growth to the ability of generative AI systems to automate content creation at scale.

Threat actors are also incorporating conversational AI and automated dialogue agents into phishing workflows. Rather than relying solely on static lure content, some campaigns use AI-generated personas capable of sustaining prolonged interactions with victims across email, messaging platforms, and collaboration tools in order to establish trust before directing users toward credential theft, malware execution, or fraudulent transactions.

Microsoft and other researchers have documented the growing use of AI-generated synthetic media, including voice and video deepfakes, within fraud operations, impersonation campaigns, and AI-enabled cybercrime ecosystems [59][60]. AI-generated media may be used to imitate executives, IT support personnel, recruiters, or business partners during phishing and fraud operations, reducing traditional trust barriers associated with social-engineering attacks. These techniques have increasingly

been observed in business email compromise (BEC), vishing, and identity-verification scams.

Researchers have also documented the use of AI-generated synthetic identities within state-aligned remote-worker and insider-access operations. In some campaigns, threat actors used AI-assisted image manipulation, translation tooling, and synthetic profile generation to support fraudulent remote-worker schemes designed to gain employment or contractor access within Western organizations. Once embedded within enterprise environments, these actors may obtain legitimate credentials, access internal systems, or deploy credential-stealing malware and persistence mechanisms from within trusted operational workflows.

7.1.2 Adaptive Malware and Dynamic Payload Generation

Threat actors increasingly incorporate AI-assisted payload generation and adaptive execution logic into modern malware development workflows. Researchers analyzing the LameHug infostealer documented the use of the Qwen 2.5-Coder model through the Hugging Face API to dynamically generate system commands during runtime execution. Because command structures may be synthesized programmatically rather than embedded statically within the malware binary, these approaches may reduce the effectiveness of traditional signature-based detection and static analysis techniques.

AI-assisted tooling may also enable malware to modify execution behavior dynamically based on the victim environment, available privileges, installed security tooling, or cloud configurations encountered during compromise. This operational adaptability reduces reliance on static payloads and allows attackers to tailor intrusion workflows in real time across enterprise environments.

Researchers have additionally documented the use of AI-generated synthetic identities within state-aligned remote-worker and insider-access operations. In several reported campaigns, DPRK-affiliated operators used AI-assisted image manipulation, translation tooling, and synthetic persona generation to support fraudulent remote-worker schemes designed to obtain legitimate access to enterprise environments. Once embedded within those environments, threat actors may gain access to internal systems, deploy credential-stealing malware, or harvest cloud authentication material through trusted operational workflows.

7.2 AI-Assisted Intrusion Operations

Threat actors are increasingly incorporating AI-assisted tooling and automation into

reconnaissance, credential validation, and post-compromise operations. Rather than conducting all operational activity manually, attackers may leverage compromised AI agents, orchestration platforms, and cloud-integrated automation frameworks already embedded within enterprise workflows.

Researchers have documented campaigns in which state-aligned threat actors used AI-enabled tooling and automation operationally during multi-stage intrusions. In these environments, compromised AI agents and orchestration platforms may function as high-value pivot points that provide indirect access to internal documentation systems, repositories, SaaS platforms, cloud resources, and enterprise databases through legitimate service workflows and delegated authentication mechanisms.

Once attackers obtain access to an MCP-connected service, AI orchestration platform, or associated authentication token, they may leverage those trusted integrations to enumerate internal resources, query enterprise systems, access repositories, or automate operational tasks using authorized machine identities. Because this activity frequently originates from legitimate service accounts, SaaS integrations, or AI-enabled workflows, malicious behavior may blend into otherwise normal cloud and application traffic, reducing the effectiveness of traditional perimeter-focused and user-behavior detection models.

This convergence between AI-enabled workflows, cloud-native infrastructure, and non-human identities significantly expands the operational scale of modern intrusions. Rather than deploying disruptive malware immediately, attackers increasingly prioritize stealthy access through trusted automation frameworks, reusable identity artifacts, and AI-assisted tooling that can accelerate reconnaissance, privilege escalation, and data discovery across interconnected enterprise environments. [51] [59] [98]

7.3 Automation, Scaling, and Cloud-Native Abuse

The integration of AI-assisted tooling into cyber operations enables attackers to scale intrusion activity across cloud-native environments with greater speed and efficiency. Automated credential validation, cloud enumeration, token replay, and SaaS discovery workflows allow threat actors to rapidly identify high-value assets and expand access across interconnected platforms following an initial compromise.

Because many enterprise environments rely heavily on APIs, service accounts, OAuth integrations, and AI-connected automation platforms, attackers increasingly operate through legitimate machine identities rather than disruptive malware execution alone. This model allows malicious activity to blend into otherwise normal SaaS, cloud, and AI-service traffic while reducing reliance on noisy persistence mechanisms traditionally

associated with endpoint malware.

AI-assisted automation may also accelerate large-scale data discovery and exfiltration. Rather than manually reviewing enterprise datasets, attackers can use automation frameworks and AI-enabled analysis to summarize sensitive information, query internal repositories, identify intellectual property, or extract targeted operational data from cloud-connected systems.

As AI adoption continues to expand across enterprise environments, the convergence between AI orchestration, cloud infrastructure, SaaS integrations, and machine identities is likely to further increase the operational complexity and scale of modern intrusion campaigns.

7.4 Generative AI vs. Agentic AI in Intrusion Operations

Current research increasingly distinguishes between the use of generative AI for content creation and the use of agentic AI systems capable of executing semi-autonomous operational workflows within enterprise environments [51][98][101]. While both technologies may support cybercriminal activity, their operational roles within intrusion campaigns differ significantly.

Generative AI is primarily used to produce content that assists human operators. Researchers have documented the use of large language models (LLMs) to generate phishing emails, malicious scripts, social-engineering content, synthetic media, malware obfuscation logic, and deceptive communication workflows at scale [98][100][101][111]. In these cases, AI functions primarily as an acceleration mechanism that improves efficiency, personalization, and scalability for human-directed operations.

Agentic AI systems introduce a different operational model in which AI-enabled agents may execute chained tasks, interact with enterprise systems, query APIs, retrieve information, invoke tools, or perform automated decision-making with reduced human involvement. In enterprise environments, these systems are increasingly integrated into development workflows, SaaS platforms, orchestration frameworks, and cloud-connected operational tooling through technologies such as Model Context Protocol (MCP) integrations and AI-connected automation pipelines [51].

Researchers have expressed growing concern that compromise of AI agents or orchestration frameworks may provide attackers with indirect access to enterprise systems through trusted automation workflows and delegated permissions. Unlike traditional generative AI usage, agentic systems may possess persistent access to APIs, SaaS platforms, cloud-management interfaces, internal documentation systems,

or development environments capable of supporting autonomous reconnaissance, lateral movement, and operational scaling [51][61].

Although fully autonomous AI-driven intrusion operations remain relatively limited in publicly documented reporting, current research suggests that the convergence of agentic AI systems, delegated authentication, cloud-native orchestration, and machine identities may significantly expand future opportunities for automated reconnaissance, persistence, and SaaS compromise within enterprise environments [3][19][51][61].

8.0 Real-World Incident Analysis

Recent intrusion campaigns demonstrate how modern infostealer operations increasingly function as the initial access layer for broader cloud compromise, SaaS abuse, identity replay, and AI-enabled intrusion activity. Rather than operating solely as credential-theft malware, contemporary infostealers frequently enable persistent access into enterprise cloud environments through the theft of reusable authentication artifacts, non-human identities (NHIs), OAuth tokens, and cloud service credentials.

The following incidents illustrate how infostealer infections, identity compromise, and cloud-native attack workflows increasingly intersect within modern enterprise breaches.

8.1 The Snowflake Data Breach (2024)

The 2024 Snowflake-related intrusions represented one of the most significant examples of infostealer-enabled cloud compromise. Investigations linked the activity to the UNC5537 threat cluster, commonly associated with the ShinyHunters cybercriminal ecosystem. Attackers obtained credentials for Snowflake customer environments through infostealer infections affecting employee and contractor systems.

In many cases, compromised credentials were harvested from systems previously infected with credential-stealing malware and later reused to authenticate directly into Snowflake cloud environments. Researchers reported that numerous affected accounts lacked multi-factor authentication (MFA), allowing attackers to access enterprise datasets using valid credentials without exploiting vulnerabilities in the Snowflake platform itself.

The operational impact was substantial. Attackers reportedly accessed data associated

with more than 165 organizations, including large-scale theft of customer records, internal datasets, and telecommunications metadata. The incident demonstrated how infostealer-derived credentials and identity replay techniques can rapidly escalate from endpoint compromise into enterprise-scale cloud breaches affecting downstream customers and third-party integrations.

8.2 Vercel and Context.ai Compromise (2026)

In 2026, a security incident involving Vercel and Context.ai highlighted the cascading risk associated with SaaS integrations and session-token compromise. According to public reporting, the incident originated from an infostealer infection affecting an employee system associated with Context.ai.

Attackers reportedly obtained authenticated session material and access tokens that enabled lateral access into interconnected enterprise environments and downstream SaaS tenants. The compromise demonstrated how modern identity-centric attacks increasingly exploit trust relationships between cloud-connected platforms rather than relying solely on direct exploitation of infrastructure vulnerabilities.

The incident also reinforced the operational risks associated with delegated authentication workflows and third-party SaaS integrations. Once attackers gain access to trusted session tokens or OAuth-connected environments, they may inherit broad access across multiple interconnected services using otherwise legitimate authentication workflows.

8.3 Storm-2139 and AI Abuse Infrastructure

Current research suggests that modern intrusion campaigns are continuing to shift away from traditional endpoint-focused compromise toward operations centered on authentication abuse, delegated access, and trusted enterprise integrations [3][19][51][61]. As organizations expand adoption of AI-enabled tooling, SaaS ecosystems, automation platforms, and distributed cloud infrastructure, attackers are increasingly prioritizing environments where authenticated access can be reused across multiple interconnected services.

Researchers have also observed growing convergence between cybercriminal operations, access-broker ecosystems, and state-aligned intrusion activity. Techniques historically associated with advanced persistent threat (APT) operations—including long-term persistence, cloud-service abuse, delegated-authentication misuse, and

operational stealth—are increasingly appearing within financially motivated campaigns targeting enterprise SaaS and cloud environments [2][3][19].

AI-assisted tooling is also expected to accelerate the scale and adaptability of phishing, malware delivery, credential abuse, and automated reconnaissance operations. Threat actors increasingly appear focused on blending malicious activity into legitimate enterprise traffic through authorized APIs, valid sessions, automation frameworks, and machine-authenticated services rather than relying exclusively on disruptive malware deployment [51][98][101].

At the same time, future campaigns are likely to place increasing emphasis on environments containing large concentrations of API keys, OAuth integrations, developer tooling, AI agents, cloud service accounts, and interconnected automation workflows. Industries with extensive third-party integrations, distributed development environments, and AI-assisted operational processes may face elevated exposure to credential theft, delegated-access abuse, and long-duration SaaS compromise [3][19][61].

These trends suggest that enterprise defense strategies will increasingly require continuous visibility into identity usage, SaaS activity, delegated authentication, cloud telemetry, and AI-connected operational systems rather than relying primarily on traditional perimeter-focused security controls.

8.4 Rapid AWS Privilege Escalation and LLMjacking Operations

Researchers have documented incidents in which attackers rapidly escalated from exposed cloud credentials to administrative control over AWS environments within minutes of initial compromise. In one reported case, threat actors obtained test credentials exposed within a publicly accessible S3 bucket and used those credentials to enumerate IAM permissions, expand privileges, and gain broad access to cloud resources in under ten minutes.

Following privilege escalation, attackers reportedly modified Lambda functions, deployed malicious workloads, and abused Amazon Bedrock services to conduct unauthorized AI inference operations associated with “LLMjacking” activity. These operations involved the misuse of cloud-hosted AI infrastructure and API access for unauthorized compute consumption and AI workload execution.

The incident demonstrated how cloud-native attack workflows increasingly combine automated credential validation, rapid privilege escalation, service-account abuse, and AI infrastructure exploitation within a single operational sequence. It also highlighted the

speed at which exposed machine identities and cloud credentials may be operationalized following initial compromise.

8.5 Storm-2139 and AI Abuse Infrastructure

The Storm-2139 threat cluster demonstrated how stolen AI credentials and cloud-based AI services can be operationalized as part of broader cybercriminal infrastructure. Researchers observed the group leveraging harvested Azure OpenAI API keys to support an illicit platform known as “de3u,” which was reportedly used to generate harmful synthetic content and bypass AI safety restrictions.

Unlike traditional credential theft operations focused solely on financial fraud or ransomware deployment, the Storm-2139 activity illustrated how compromised AI credentials may be monetized directly through unauthorized inference operations and abuse of cloud-hosted generative AI services. By using valid API keys associated with legitimate enterprise tenants, attackers were able to consume AI resources through trusted service workflows while reducing operational visibility into malicious activity.

The incident highlighted the growing convergence between infostealer operations, cloud identity abuse, and AI infrastructure compromise. As organizations increasingly integrate generative AI services into enterprise workflows, stolen API credentials effectively function as reusable access tokens to high-value compute resources capable of supporting large-scale automated content generation, synthetic media production, and other AI-enabled abuse operations.

8.6 Polyfill.io and DPRK Operational Exposure

The Polyfill.io supply-chain incident demonstrated how operational security failures within threat actor infrastructure can expose broader state-aligned cyber activity. Investigations into the Polyfill.io compromise reportedly identified operational exposure linked to DPRK-affiliated infrastructure after an operator inadvertently infected their own system with infostealer malware, exposing credentials and administrative artifacts associated with the broader operation [20][109].

Analysis of recovered infostealer logs reportedly exposed credentials, operational artifacts, and administrative access associated with infrastructure tied to the Polyfill.io compromise. Researchers described the incident as a rare example in which credential-stealing malware unintentionally revealed internal operational details associated with a state-aligned cyber campaign.

The incident also highlighted the interconnected nature of modern cybercrime ecosystems. Infostealers increasingly affect not only enterprise victims, but also threat actors themselves, creating operational exposure risks within criminal and state-sponsored infrastructure. Additionally, the Polyfill.io compromise reinforced the growing importance of software supply-chain security, particularly in environments where trusted JavaScript libraries and third-party dependencies maintain broad access across web applications and enterprise platforms.

8.7 Hugging Face Typosquatting and ValleyRAT

In 2026, researchers identified a typosquatting campaign targeting users of AI and machine-learning tooling hosted on the Hugging Face platform. Threat actors created a fraudulent repository designed to imitate a legitimate OpenAI-related project, ultimately distributing the ValleyRAT infostealer malware through malicious model downloads and developer tooling workflows.

According to reporting, the malicious repository accumulated hundreds of thousands of downloads within a short period of time before removal. The campaign demonstrated how attackers increasingly target trusted AI-development ecosystems and open-source machine-learning platforms as malware delivery mechanisms. Rather than relying solely on traditional phishing workflows, threat actors leveraged trust associated with AI tooling repositories, developer communities, and open-source distribution channels to deploy credential stealers and compromise developer environments.

The ValleyRAT campaign also underscored the growing security risks associated with AI supply-chain ecosystems. As organizations increasingly integrate external models, repositories, plugins, and AI-assisted development frameworks into operational workflows, malicious packages and typosquatted repositories may provide attackers with direct access to developer credentials, cloud authentication material, API keys, and internal enterprise environments.

8.8 Lessons Learned from Modern Infostealer-Enabled Intrusions

Collectively, these incidents demonstrate a broader shift in modern intrusion operations away from traditional endpoint-centric malware activity and toward identity-centric compromise targeting cloud and SaaS environments. In each case, attackers relied heavily on reusable authentication artifacts, delegated trust relationships, cloud-native workflows, or non-human identities rather than exploiting vulnerabilities directly within enterprise infrastructure.

These operations also illustrate the growing convergence between infostealers, SaaS compromise, OAuth abuse, cloud identity systems, and AI-enabled infrastructure. As organizations continue integrating cloud-native services, AI orchestration platforms, and interconnected SaaS ecosystems into operational workflows, compromise of a single endpoint or authentication token may rapidly expand into broader enterprise-wide access through trusted service relationships.

The operational speed observed in many of these incidents further underscores the limitations of traditional perimeter-focused detection strategies. Automated credential validation, token replay, and cloud-native privilege escalation workflows allow attackers to establish persistence and expand access within minutes of initial compromise, often before traditional security operations teams can respond effectively.

9.0 The Underground Economy and Monetization

The rapid growth of infostealer campaigns is driven not only by technical innovation, but also by the profitability and scalability of the underground cybercrime economy. Modern credential theft operations increasingly function as organized commercial ecosystems in which malware developers, initial-access brokers, credential resellers, and cloud-abuse operators specialize in distinct stages of the attack lifecycle.

Within these ecosystems, stolen credentials, session cookies, OAuth tokens, API keys, and cloud service accounts are treated as high-value commodities that can be resold, reused, or operationalized across multiple intrusion campaigns. The rise of Malware-as-a-Service (MaaS), cloud-based automation, and AI-enabled infrastructure has further lowered the barrier to entry for cybercriminal operations while significantly increasing the speed and scale of identity-centric attacks.

9.1 Credential Markets and Access Brokerage

Underground marketplaces specializing in stolen credentials and access brokerage have become central components of the modern cybercrime ecosystem. Platforms such as Russian Market, 2Easy Market, and InfoLog Empire facilitate the sale and exchange of infostealer logs containing browser credentials, session cookies, cloud access keys, OAuth tokens, cryptocurrency wallets, and enterprise authentication material harvested from compromised systems.

Rather than monetizing stolen credentials individually, many operators aggregate and

package infostealer data into searchable “logs” that can be filtered by geographic region, browser type, enterprise domain, cloud provider, or presence of specific credentials such as AWS keys, GitHub tokens, or VPN access. This operational model allows threat actors to rapidly identify high-value enterprise targets without conducting traditional reconnaissance themselves.

The emergence of initial-access brokers further industrializes these operations. Specialized actors increasingly purchase infostealer-derived credentials and resell validated access to ransomware groups, state-aligned operators, extortion crews, and financially motivated cybercriminal organizations. As a result, a single endpoint infection may ultimately support multiple downstream intrusion campaigns across unrelated threat actors.

Asset Type	Typical Underground Value
Social media credentials	\$10–\$50
Stolen email accounts	\$10–\$65
SSO and identity tokens	\$100–\$250
Cloud service credentials	\$30–\$200
Full identity packages (“Fullz”)	\$100–\$500

The increasing value of cloud credentials and reusable identity artifacts reflects the broader transition toward identity-centric intrusion operations targeting SaaS platforms, cloud infrastructure, and AI-enabled environments.

9.2 LLMjacking and AI Compute Theft

The theft of AI API keys and cloud-based AI credentials has contributed to the emergence of “LLMjacking,” a form of cloud abuse in which attackers consume unauthorized AI compute resources using stolen credentials [28][32][43][61]. Unlike traditional credential-theft operations focused primarily on account compromise or ransomware deployment, LLMjacking campaigns directly monetize access to high-cost generative AI infrastructure and cloud-hosted inference services.

Threat actors increasingly target API keys associated with platforms such as OpenAI, Azure OpenAI, Amazon Bedrock, Vertex AI, Gemini, and Anthropic environments because these credentials provide immediate access to scalable cloud-hosted compute resources capable of supporting automated content generation, synthetic media production, spam operations, and AI-assisted malware development [28][32][43]. Researchers have also observed stolen AI credentials being resold on underground marketplaces at discounted rates as pre-funded access to expensive generative AI infrastructure [61].

Multiple researchers have documented incidents involving unauthorized usage of generative AI platforms that generated substantial financial impact within short timeframes. In several reported cases, exposed API credentials enabled attackers to generate tens of thousands of dollars in unauthorized compute consumption before detection occurred, including incidents involving unauthorized Gemini API usage and AI-service abuse across cloud-hosted environments [28][29][30][43].

Incident Type	Duration	Reported Financial Impact	Root Cause
Gemini API abuse	48 hours	\$82,000	Exposed API key
Google Cloud AI abuse	36 hours	\$128,000	Unauthorized API usage
Average AI API breach	Ongoing	~\$700,000 annually	Recovery, downtime, and remediation costs

These incidents highlight how AI credentials increasingly function as pre-funded access

tokens to scalable cloud infrastructure. Because many generative AI services rely on consumption-based billing models tied to token usage or compute cycles, unauthorized access may rapidly generate significant operational and financial consequences for victim organizations. Researchers documented incidents in which stolen Gemini API credentials generated approximately \$82,000 in unauthorized compute usage within 48 hours [28].

9.3 Cloud-Native Abuse and Infrastructure Monetization

Modern attackers increasingly monetize compromised cloud environments directly through infrastructure abuse rather than traditional ransomware deployment alone. Once attackers obtain cloud credentials, OAuth tokens, or service-account access, they may leverage enterprise cloud infrastructure to deploy workloads, conduct spam operations, host malicious content, or perform unauthorized AI inference activity at scale.

Cloud-native abuse operations frequently involve services such as AWS Lambda, Azure Functions, Kubernetes clusters, and AI inference APIs that allow attackers to operationalize compromised environments rapidly while blending into otherwise legitimate cloud activity. Researchers have documented campaigns in which stolen AWS credentials were used to invoke Amazon Bedrock APIs, deploy malicious serverless workloads, or conduct automated inference operations associated with LLMjacking activity.

Because these operations rely heavily on legitimate cloud APIs and authorized service workflows, detection can be significantly more difficult than traditional malware execution on endpoints. In many cases, malicious activity appears operationally similar to normal enterprise automation, DevOps activity, or AI-assisted workloads, reducing visibility for traditional security monitoring systems.

9.4 Financial and Operational Impact

The financial consequences of modern infostealer-enabled cloud compromise extend far beyond credential theft itself. Organizations affected by AI credential abuse, cloud identity compromise, and SaaS intrusions may incur substantial costs associated with unauthorized compute usage, incident response, regulatory exposure, operational disruption, legal liability, and long-term remediation efforts.

AI-related cloud abuse presents unique operational risks because generative AI platforms often scale consumption automatically based on API demand. As a result, attackers using stolen AI credentials may rapidly generate significant charges within

hours through large-scale inference requests, synthetic media generation, or automated content-production workflows.

The operational impact of these incidents also extends into broader enterprise risk. Compromise of cloud credentials and machine identities may expose sensitive intellectual property, source code repositories, proprietary datasets, customer records, and AI training pipelines while simultaneously enabling persistent access across interconnected SaaS ecosystems.

Collectively, these trends demonstrate that modern infostealer operations increasingly function as financially motivated cloud abuse campaigns targeting reusable trust relationships, scalable infrastructure, and monetizable compute resources rather than traditional endpoint compromise alone.

10.0 Industry Impact and Sector Exposure

Industry reporting consistently identifies Manufacturing, Healthcare, Technology, and Financial Services among the sectors most heavily impacted by ransomware, credential theft, and cloud identity compromise due to operational dependency on interconnected digital infrastructure and low tolerance for disruption [2][3][19].

The growing convergence between cloud identity abuse, SaaS compromise, non-human identities (NHIs), and AI-enabled intrusion operations has expanded the operational and financial consequences of these attacks far beyond traditional credential theft.

Modern infostealer campaigns increasingly target sectors with high operational dependency on cloud-connected workflows, sensitive data, distributed workforces, and interconnected SaaS ecosystems. In many cases, attackers prioritize environments where disruption, extortion pressure, or downstream supply-chain impact can maximize financial leverage.

Industry Sector	Observed Impact	Primary Operational Risk
Manufacturing	High ransomware and extortion exposure	Low tolerance for operational downtime

Healthcare	High breach severity and recovery costs	Patient-data theft and operational disruption
Technology	Frequent supply-chain targeting	Developer credential theft and SaaS compromise
Finance / BFSI	High credential and identity targeting	SSO abuse and financial fraud

10.1 Manufacturing Sector

Manufacturing organizations remain among the most frequently targeted sectors in modern intrusion campaigns. Researchers have consistently identified manufacturing as a leading target for ransomware operators, credential-stealing malware, and cloud-based extortion activity due to the sector's dependence on operational continuity and low tolerance for downtime. [2] [3] [19]

Infostealer infections within manufacturing environments may expose VPN credentials, SaaS authentication tokens, operational technology (OT) access systems, cloud-connected production workflows, and supplier integrations that enable attackers to expand access rapidly across interconnected infrastructure. Because production interruptions can generate immediate financial losses and supply-chain disruption, manufacturing organizations are often viewed as highly susceptible to extortion pressure following compromise.

The growing integration of cloud-connected industrial systems, remote-access tooling, and AI-assisted operational platforms further increases exposure to identity-centric attacks targeting reusable authentication artifacts and machine identities.

10.2 Healthcare Sector

Healthcare organizations continue to experience some of the highest operational and financial impacts associated with cyber incidents. Threat actors frequently target

healthcare providers, insurers, and medical research organizations because of the high value of patient records, insurance data, proprietary research, and operational urgency surrounding healthcare delivery systems.

Infostealer-driven intrusions within healthcare environments may expose electronic health records (EHRs), SaaS authentication tokens, privileged service accounts, cloud-hosted medical data, and interconnected third-party healthcare platforms. The widespread adoption of cloud-based collaboration systems and remote healthcare technologies has further expanded the attack surface available to credential-stealing operations.

Researchers have projected that healthcare organizations may experience some of the highest breach-recovery costs among major industries due to regulatory exposure, operational disruption, patient-safety concerns, and the complexity of remediating cloud-connected healthcare environments following compromise. [3] [29]

10.3 Technology Sector

Technology companies remain high-value targets for infostealer campaigns due to their access to source code repositories, software supply chains, cloud infrastructure, developer credentials, and AI-enabled development environments. Threat actors frequently target developers, DevOps personnel, and SaaS administrators whose systems contain GitHub tokens, CI/CD secrets, cloud API keys, SSH credentials, and machine identities capable of enabling downstream supply-chain compromise.

The increasing adoption of AI-assisted development tooling and cloud-native orchestration platforms further expands operational risk within the technology sector. Malicious browser extensions, typosquatted repositories, compromised npm packages, and AI-themed malware campaigns increasingly target software-development ecosystems as a mechanism for credential theft and persistence.

Compromise within technology environments may also produce cascading downstream impact across customers, vendors, and software supply chains, making technology firms particularly attractive targets for large-scale credential-harvesting and supply-chain operations.

10.4 Financial Services and BFSI

Financial institutions and broader banking, financial services, and insurance (BFSI) environments remain heavily targeted by credential-theft operations due to the direct

monetization opportunities associated with financial fraud, account takeover, and identity abuse.

Modern attacks against BFSI organizations increasingly focus on single sign-on (SSO) systems, cloud identity platforms, OAuth integrations, and SaaS-connected financial workflows rather than traditional endpoint compromise alone. Threat actors commonly target banking credentials, session cookies, cloud-based authentication tokens, and payment-processing environments capable of supporting fraud operations or large-scale account compromise.

The financial sector also faces elevated risk from AI-enhanced phishing, business email compromise (BEC), and synthetic identity fraud operations designed to bypass traditional trust and verification processes. As financial institutions continue expanding cloud adoption and AI integration, identity-centric attacks targeting reusable authentication artifacts and non-human identities are likely to remain a major operational threat.

11.0 Detection, Monitoring, and Mitigation Strategies

The evolution of infostealer campaigns from traditional credential theft toward identity-centric cloud compromise requires a corresponding shift in defensive strategy. Conventional endpoint-focused security models are increasingly insufficient against attacks that rely on session replay, OAuth abuse, non-human identities (NHIs), cloud-native automation, and AI-assisted operational workflows.

Modern detection and mitigation efforts must correlate endpoint telemetry, identity signals, SaaS activity, cloud API usage, and AI-enabled operational workflows to identify compromise before attackers establish persistent access across interconnected enterprise environments. Because many contemporary intrusion campaigns leverage legitimate authentication mechanisms and authorized service workflows, organizations must increasingly prioritize behavioral analytics, identity governance, and cloud-native monitoring over signature-based malware detection alone.

11.1 MITRE ATT&CK Mapping

Modern infostealer campaigns align closely with multiple MITRE ATT&CK techniques spanning phishing, execution, credential theft, defense evasion, cloud compromise, and identity abuse. Mapping these behaviors to ATT&CK techniques provides defenders with a structured framework for identifying intrusion stages and prioritizing defensive controls across enterprise environments.

Attack Phase	MITRE ATT&CK ID	Technique and Operational Context
Initial Access	T1566.002	Spearphishing links delivering fake verification interfaces and ClickFix workflows
Execution	T1204.002	User-assisted execution through malicious commands pasted into Run dialogs or terminals
Defense Evasion	T1027	Obfuscated files, encrypted strings, and dynamically generated command execution
Credential Access	T1539	Theft and replay of web session cookies and authenticated browser sessions
Discovery	T1083	File and directory discovery targeting .env files, cloud credentials, and AI secrets
Persistence	T1098	OAuth abuse, malicious application consent, and delegated authentication persistence
Lateral Movement	T1078	Use of valid accounts, API keys, and service identities for cloud access
Command and Control	T1105	Cloud-hosted payload delivery and SaaS-based communication workflows

This mapping demonstrates how modern infostealer campaigns increasingly combine endpoint compromise, identity abuse, and cloud-native operational workflows within a single intrusion lifecycle.

11.2 Behavioral Detection Strategies

Traditional signature-based detection remains insufficient against modern infostealer operations that rely heavily on legitimate service workflows, delegated authentication, and AI-assisted payload generation. As a result, organizations increasingly require behavioral and identity-centric monitoring strategies capable of detecting anomalous activity across endpoints, SaaS environments, cloud infrastructure, and AI-integrated workflows.

Cloud monitoring platforms should audit for suspicious API activity involving long-lived IAM credentials, abnormal token usage, unauthorized OAuth applications, and unusual AI-service invocation patterns. Researchers have specifically recommended monitoring services such as AWS CloudTrail for anomalous InvokeModel API activity associated with AI inference abuse and LLMjacking operations, particularly when requests originate from long-term credentials rather than ephemeral cloud roles.

Browser telemetry and endpoint analytics also remain important because modern infostealers frequently target browser session stores, cloud authentication material, and local credential caches. Security teams should monitor for browser processes launching with unusual execution flags, unexpected outbound connections to messaging platforms commonly used for command-and-control (C2) operations, and abnormal access to browser credential databases or cloud configuration files.

Organizations should additionally audit detection infrastructure itself to identify “silent zombie” detection rules — monitoring logic that remains enabled operationally but no longer receives valid telemetry due to dead data sources, outdated integrations, or improperly configured pipelines. These gaps may create false assumptions of visibility while allowing identity-centric attacks to operate undetected within enterprise environments.

As AI adoption expands, organizations may also require AI-aware runtime monitoring capable of correlating suspicious sequences of tool calls, database queries, API requests, and orchestration activity associated with compromised AI agents or MCP-connected workflows.

11.3 Identity and Cloud Security Controls

Because modern intrusion campaigns increasingly target reusable authentication artifacts and non-human identities, organizations must strengthen identity governance and cloud authentication controls beyond traditional password-based security models.

Phishing-resistant authentication mechanisms such as FIDO2 passkeys and device-bound session credentials (DBSC) can significantly reduce the effectiveness of session replay and browser-cookie theft by binding authentication material to trusted hardware or device contexts. Organizations should also minimize reliance on long-lived access keys and static service-account credentials wherever possible in favor of short-lived, ephemeral identity models.

OAuth governance has become increasingly important within cloud-native environments. Security teams should continuously audit OAuth application permissions, monitor delegated authentication grants, restrict high-risk third-party integrations, and enforce conditional-access controls for AI-enabled workflows and SaaS-connected automation platforms.

Automated secret-management systems should also be implemented to detect exposed credentials within repositories, development environments, and cloud workloads. Continuous scanning and automated credential rotation significantly reduce the operational lifespan of exposed API keys, OAuth tokens, and machine identities harvested through infostealer activity.

11.4 AI and Developer Toolchain Hardening

The growing convergence between AI tooling, developer ecosystems, and cloud-native infrastructure requires organizations to secure AI-enabled workflows and software supply chains as part of broader enterprise defense strategies.

Organizations should enforce allowlist policies for browser and IDE extensions, particularly within developer environments containing cloud credentials, CI/CD secrets, AI API keys, or privileged SaaS access. Security reviews should prioritize extensions requesting broad browser permissions, persistent authentication access, or integration with AI-enabled collaboration platforms.

Supply-chain security controls should additionally include repository-scanning, package-validation, dependency-monitoring, and typosquatting detection mechanisms capable of identifying malicious npm packages, AI-themed malware, or compromised developer tooling before deployment within enterprise environments.

Because many modern attacks rely on user-assisted execution workflows such as

ClickFix campaigns, organizations should also harden operating-system policies and endpoint configurations. Examples include restricting access to Windows Run dialogs, limiting PowerShell execution policies, disabling unnecessary scripting interfaces, and implementing application-control policies that reduce opportunities for malicious command execution.

11.5 Financial and Operational Guardrails

The rise of AI compute theft and LLMjacking introduces new financial risks that traditional cybersecurity programs may not fully address. Organizations using cloud-hosted AI services should implement operational guardrails designed to limit the impact of unauthorized API consumption and AI-service abuse.

Recommended controls include hard spending limits, automated billing alerts, anomaly-based consumption monitoring, and rate-limiting mechanisms for AI inference APIs and cloud-hosted generative AI workloads. Organizations should also segment AI workloads operationally to reduce the risk that compromise of a single API key or OAuth token enables unrestricted access across enterprise AI infrastructure.

Incident-response planning should additionally incorporate cloud-native identity compromise scenarios involving OAuth abuse, AI service hijacking, session replay, and unauthorized API consumption. Because many modern intrusions prioritize persistent access through delegated authentication workflows rather than destructive malware deployment alone, organizations must increasingly prepare for long-duration cloud compromise and identity abuse operations.

11.6 Security Awareness, Human Risk, and Social Engineering Resilience

Modern infostealer campaigns increasingly rely on human interaction rather than direct technical exploitation alone. Techniques such as ClickFix verification lures, phishing, malicious OAuth consent prompts, deepfake impersonation, fake software updates, and AI-generated social-engineering campaigns are specifically designed to manipulate users into voluntarily executing malicious actions or authorizing attacker-controlled access. As a result, employee awareness and behavioral resilience remain critical components of enterprise defense strategies.

Traditional phishing-awareness programs focused primarily on suspicious links and grammatical anomalies are increasingly insufficient against modern AI-enhanced social-engineering operations. Generative AI enables attackers to create highly

convincing emails, realistic fake websites, synthetic voice and video impersonations, and personalized phishing content that closely resembles legitimate business communication. Organizations must therefore expand security-awareness programs beyond basic phishing detection to include training focused on identity abuse, delegated authentication risks, AI-enhanced deception techniques, and user-assisted malware execution workflows.

Security-awareness initiatives should specifically educate users on modern attack patterns such as fake CAPTCHA interfaces, ClickFix-style verification prompts, OAuth consent abuse, malicious browser extensions, typosquatted repositories, and fraudulent AI tooling downloads. Employees should understand that legitimate websites, SaaS platforms, and IT personnel will not request users to paste PowerShell commands into terminal windows, authorize unknown OAuth applications, or bypass endpoint-security warnings as part of standard operational workflows.[100] [101] [111]

Organizations should also incorporate scenario-based exercises and simulated social-engineering campaigns designed to reflect current threat activity rather than relying solely on traditional phishing simulations. Training programs should include realistic simulations involving SaaS authentication prompts, MFA fatigue attacks, deepfake impersonation attempts, AI-generated communications, and cloud-service abuse scenarios that mirror modern identity-centric intrusion techniques.

Because many attacks now target developers, administrators, and privileged users directly, security-awareness programs should additionally include role-specific training for personnel with access to cloud infrastructure, CI/CD environments, SaaS administration platforms, AI tooling, and privileged machine identities. These users frequently possess elevated access to API keys, OAuth integrations, service accounts, and cloud credentials that can significantly amplify the impact of a successful compromise.

Ultimately, modern security awareness must evolve from basic phishing education toward broader human-risk management focused on identity protection, delegated-access security, cloud-service trust relationships, and AI-enabled deception. As attackers increasingly combine social engineering with cloud-native identity abuse and AI-assisted operational workflows, human resilience remains one of the most important defensive layers within enterprise environments.

11.7 Early Detection and Proactive Infostealer Response

Recent research demonstrates that infostealer infections can sometimes be identified and contained before attackers complete ransomware staging, privilege escalation, or

large-scale cloud compromise. As modern intrusion campaigns increasingly rely on stolen credentials, session cookies, OAuth tokens, and reusable identity artifacts, organizations have begun adopting proactive monitoring strategies focused on early identity exposure rather than waiting for destructive malware deployment or data exfiltration events.

One emerging defensive approach involves continuous monitoring of underground marketplaces and infostealer-log ecosystems for exposed enterprise credentials and authentication material. Researchers documented cases in which organizations identified stolen Microsoft Entra session cookies and VPN credentials within hours of their appearance on criminal marketplaces, allowing defenders to invalidate sessions, rotate credentials, and disrupt attacker operations before ransomware deployment occurred.

Threat-intelligence providers and security teams increasingly treat infostealer infections as early-warning indicators of broader compromise rather than isolated credential-theft events. Because infostealer logs frequently contain browser session cookies, SaaS authentication material, cloud credentials, and developer secrets, exposure of a single infected endpoint may indicate elevated risk for downstream cloud compromise, initial-access brokerage, or ransomware operations.

Organizations are also adopting deception-based techniques designed to detect credential misuse before operational exploitation occurs. Researchers have proposed the use of monitored honeypot credentials embedded within repositories, CI/CD pipelines, documentation systems, and cloud environments. When attackers validate or operationalize those credentials after acquiring infostealer logs, defenders receive immediate indicators of compromise associated with credential enumeration and access-broker activity.

Modern defensive strategies increasingly emphasize rapid response timelines because attackers frequently operationalize stolen credentials within minutes or hours of compromise. Recorded Future research highlighted the growing scale and speed of infostealer-driven identity exposure, noting that compromised credentials increasingly serve as the initial access layer for ransomware, SaaS compromise, and cloud-native intrusion campaigns.

Collectively, these trends indicate that effective defense against modern infostealer campaigns requires continuous identity monitoring, proactive credential exposure detection, rapid token invalidation, and cloud-native incident response workflows capable of disrupting attackers before they establish persistent access across enterprise environments.

12.0 Threat Evolution and Outlook

Current research suggests that modern intrusion campaigns are continuing to shift away from traditional endpoint-focused compromise toward operations centered on authentication abuse, delegated access, and trusted enterprise integrations [3][19][51][61]. As organizations expand adoption of AI-enabled tooling, SaaS ecosystems, automation platforms, and distributed cloud infrastructure, attackers are increasingly prioritizing environments where authenticated access can be reused across multiple interconnected services.

Researchers have also observed growing convergence between cybercriminal operations, access-broker ecosystems, and state-aligned intrusion activity. Techniques historically associated with advanced persistent threat (APT) operations—including long-term persistence, cloud-service abuse, delegated-authentication misuse, and operational stealth—are increasingly appearing within financially motivated campaigns targeting enterprise SaaS and cloud environments [2][3][19].

AI-assisted tooling is also expected to accelerate the scale and adaptability of phishing, malware delivery, credential abuse, and automated reconnaissance operations. Threat actors increasingly appear focused on blending malicious activity into legitimate enterprise traffic through authorized APIs, valid sessions, automation frameworks, and machine-authenticated services rather than relying exclusively on disruptive malware deployment [51][98][101].

At the same time, future campaigns are likely to place increasing emphasis on environments containing large concentrations of API keys, OAuth integrations, developer tooling, AI agents, cloud service accounts, and interconnected automation workflows. Industries with extensive third-party integrations, distributed development environments, and AI-assisted operational processes may face elevated exposure to credential theft, delegated-access abuse, and long-duration SaaS compromise [3][19][61].

These trends suggest that enterprise defense strategies will increasingly require continuous visibility into identity usage, SaaS activity, delegated authentication, cloud telemetry, and AI-connected operational systems rather than relying primarily on traditional perimeter-focused security controls.

12.1 The Shift Toward Identity-Centric Intrusions

Future intrusion campaigns are likely to continue moving away from traditional malware-heavy operations toward attacks centered on identity replay, delegated authentication abuse, and trusted service workflows. Rather than repeatedly bypassing multi-factor authentication (MFA) or exploiting endpoint vulnerabilities directly, attackers increasingly focus on harvesting reusable trust relationships that provide authenticated access to cloud and SaaS environments.

This evolution significantly changes the operational dynamics of enterprise compromise. Session cookies, OAuth grants, machine identities, AI API keys, and cloud service credentials increasingly function as the primary operational currency of modern cybercrime ecosystems. As a result, future attacks will likely prioritize persistence through identity abuse rather than visible malware deployment.

12.2 AI as an Operational Force Multiplier

Generative AI and automation platforms are expected to continue lowering operational barriers for cybercriminal organizations while increasing the speed and scalability of intrusion activity. AI-assisted tooling may further accelerate phishing generation, malware adaptation, reconnaissance, cloud enumeration, and data analysis workflows that previously required significant manual effort from threat actors.

At the same time, AI systems themselves are increasingly becoming operational infrastructure within enterprise environments. AI agents connected to cloud APIs, SaaS integrations, internal repositories, and enterprise databases may function as high-value pivot points capable of amplifying the impact of identity compromise and delegated-access abuse.

Although many fully autonomous attack concepts remain relatively immature operationally, the growing convergence between AI-enabled workflows and cloud-native infrastructure is likely to increase both the complexity and scale of future intrusion campaigns.

12.3 The Expansion of Cloud and SaaS Attack Surfaces

The continued growth of SaaS ecosystems, third-party integrations, cloud-native development workflows, and machine-to-machine authentication will likely expand the attack surface available to identity-centric threat actors. Organizations increasingly rely on interconnected APIs, OAuth applications, CI/CD systems, AI orchestration frameworks, and cloud-managed services that exchange authentication material continuously across enterprise environments.

This architectural model creates substantial operational dependencies on trust relationships that may be difficult to inventory, monitor, or revoke quickly following compromise. As a result, future intrusion campaigns are likely to focus heavily on OAuth abuse, delegated authentication, SaaS integrations, and non-human identities capable of enabling persistent cross-platform access.

12.4 The Future of Enterprise Defense

Defensive strategies will likely continue shifting toward identity-first security architectures emphasizing behavioral analytics, zero-trust principles, cloud-native telemetry, and continuous authentication validation. Traditional perimeter-focused and signature-based security models are increasingly ineffective against attacks operating through legitimate cloud APIs, authorized service accounts, and delegated authentication workflows.

Organizations will likely require deeper integration between endpoint telemetry, identity governance, SaaS monitoring, AI-runtime visibility, and cloud-security analytics in order to identify modern intrusion activity effectively. Security programs that fail to adapt to identity-centric and AI-enabled threat models may face increasing difficulty detecting compromise before attackers establish persistence across interconnected cloud environments.

Ultimately, the evolution of infostealer ecosystems demonstrates that modern cybercrime is no longer centered solely on malware deployment, but on the large-scale acquisition, monetization, and operationalization of digital trust relationships across cloud, SaaS, and AI-enabled enterprise ecosystems.

12.5 Emerging Industry Targeting Trends

Current research suggests that future intrusion campaigns are likely to increasingly target environments with dense concentrations of machine identities, AI-enabled automation, SaaS integrations, and cloud-native operational workflows [3][19][51][61].

While Manufacturing, Healthcare, Financial Services, and Technology sectors currently remain among the most heavily targeted industries, threat activity increasingly reflects a broader shift toward environments where trusted identities and interconnected cloud services provide scalable operational leverage.

Historically, cybercriminal operations frequently prioritized industries associated with direct financial gain or operational disruption. More recent research indicates that

attackers increasingly target organizations based on identity density, cloud-service integration, delegated authentication exposure, and the presence of reusable authentication artifacts capable of enabling downstream compromise across interconnected enterprise ecosystems.

Researchers have noted growing attacker interest in environments with extensive SaaS adoption, AI-enabled automation, CI/CD infrastructure, machine-to-machine authentication, and developer-centric workflows. Organizations operating large cloud-native environments may possess substantial concentrations of API keys, OAuth integrations, non-human identities (NHIs), AI agents, and cloud service accounts that can provide broad operational access following compromise.

This trend may increasingly expand targeting sectors such as SaaS providers, AI startups, logistics and transportation companies, telecommunications providers, biotech organizations, legal services, consulting firms, and critical infrastructure operators. These industries frequently rely on interconnected cloud platforms, third-party integrations, distributed workforces, and AI-enabled operational tooling that may amplify the impact of credential theft and delegated-authentication abuse.

Supply-chain positioning is also becoming an increasingly important targeting factor. Rather than compromising organizations solely for direct financial extortion, attackers increasingly target vendors, software providers, managed service providers, and cloud-connected technology ecosystems capable of enabling downstream access into multiple enterprise environments simultaneously.

As organizations continue integrating AI agents, automation frameworks, and cloud-native orchestration platforms into enterprise workflows, future intrusion campaigns are likely to prioritize environments where machine identities, delegated trust relationships, and cloud-connected operational tooling provide scalable opportunities for persistence, lateral movement, and long-duration access.

13.0 Conclusion

The evolution of modern infostealer campaigns reflects a broader transformation in the cyber threat landscape from traditional endpoint-centric malware activity toward identity-centric cloud compromise and AI-enabled intrusion operations. Contemporary infostealers no longer function solely as tools for harvesting passwords or banking credentials; they increasingly operate as scalable identity-collection platforms capable of enabling SaaS compromise, cloud-service abuse, OAuth persistence, AI compute theft, and long-duration access across interconnected enterprise environments.

This shift has been accelerated by the rapid adoption of cloud-native infrastructure, SaaS ecosystems, AI-enabled tooling, and machine-to-machine authentication workflows. As organizations increasingly rely on APIs, OAuth integrations, non-human identities (NHIs), AI agents, and cloud orchestration platforms, attackers have adapted their operational models to target reusable trust relationships rather than relying exclusively on disruptive malware deployment or direct exploitation of vulnerabilities.

The growing convergence between infostealer malware, cloud identity abuse, AI-enabled offensive tooling, and automated intrusion workflows demonstrates how modern attacks increasingly prioritize stealth, scalability, and operational persistence. Session cookies, OAuth grants, cloud API keys, AI service credentials, and delegated authentication tokens have become high-value operational assets within both financially motivated and state-aligned cyber campaigns. In many environments, compromise of a single low-privilege endpoint may provide indirect access to broader cloud ecosystems through interconnected SaaS workflows, developer tooling, and machine identities.

Research reviewed throughout this paper also suggests that future intrusion activity is likely to continue shifting toward industries and environments with dense concentrations of cloud integrations, AI-enabled operational tooling, and reusable identity artifacts. Organizations operating large SaaS ecosystems, AI-assisted workflows, CI/CD environments, and distributed cloud infrastructure may face increasing exposure to identity replay, delegated-authentication abuse, and cloud-native persistence techniques.

At the same time, the growing speed of modern intrusion operations significantly challenges traditional defensive models. Automated credential validation, token replay, cloud enumeration, and AI-assisted operational workflows increasingly allow attackers to establish persistence and expand access within minutes of initial compromise. These trends suggest that traditional perimeter-focused and signature-based security strategies alone may no longer provide sufficient visibility into modern identity-centric attacks.

Effective defense against modern infostealer campaigns increasingly requires an integrated security approach centered on identity governance, cloud-native telemetry, behavioral analytics, SaaS visibility, proactive credential monitoring, and human-risk reduction. Organizations must also recognize that social engineering, delegated trust abuse, and AI-enhanced deception techniques remain central operational components of many modern intrusion campaigns.

Ultimately, modern infostealer ecosystems demonstrate that the future of cyber compromise is increasingly centered on the theft, replay, and operationalization of digital trust relationships across cloud, SaaS, and AI-enabled enterprise environments.

As attackers continue adapting to cloud-native and AI-driven operational models, organizations will likely need to evolve beyond traditional endpoint-focused security strategies toward continuous identity-aware defense architectures capable of operating across increasingly interconnected digital ecosystems.

References

- [1] Vectra AI. "Infostealers: The Staggering Scale of Credential Theft."³
- [2] Ankura. "The Silent Epidemic: Infostealers and the Evolution of Cybercrime in 2025."¹
- [3] Microsoft. "Digital Defense Report 2025."²
- [5] Recorded Future. "Behind the Curtain: How Lumma Affiliates Operate."⁴

- [6] SentinelOne. "Infostealer 101: Understanding Credential and Token Theft."³⁰
- [7] Qualys. "Unmasking Lumma Stealer: Deceptive Tactics with Fake CAPTCHA."¹⁴
- [8] Microsoft Security Blog. "Lumma Stealer: Delivery Techniques and Capabilities."¹⁰
- [10] HivePro. "Brand Hijack: Who is Pretending to be ShinyHunters?"¹⁶
- [19] Recorded Future. "2025 Cloud Threat Hunting and Defense Landscape."¹¹
- [20] Infostealers.com. "Infostealer Infection Unmasks DPRK Spies in U.S. Crypto."³³
- [28] Point Guard AI. "When a Stolen AI API Key Becomes an \$82,000 Problem."³⁶
- [29] Akamai. "2026 API Security Impact Study."³⁸
- [30] Google Cloud Reddit. "Facing possible bankruptcy after unauthorized Gemini API usage."³⁷
- [32] Kuboid Secure Layer. "LLMjacking: How AI API Key Theft Works."⁸
- [33] Medium (H7W). "Technical Analysis of the LameHug Campaign (APT28)."¹²
- [36] AI Incident Database. "Incident 1220: LAMEHUG Malware Integrates LLM."²⁹
- [41] Red Canary. "Cloud Service Hijacking: Detection and Response."¹⁷
- [43] NHIMG. "AI LLM Hijack Breach: Access Key Exploitation."³⁹
- [51] TechRxiv. "Security Challenges of LLMs in Cloud-Native Environments."⁹
- [59] Microsoft Blog. "Disrupting Cybercrime Abusing Gen AI: Storm-2139."³¹
- [60] TechTarget. "Microsoft Targets AI Deepfake Cybercrime Network in Lawsuit."³²
- [61] Entro Labs. "LLMjacking Report: How Attackers Hijack AI Using Compromised NHIs."⁵
- [73] Nocturnal Knight. "Supply Chain Vulnerabilities: GitHub Tokens and IDE Extensions."⁴¹
- [74] Qualys. "Comprehensive Mitigation Strategies for AI Model Security."⁴²
- [77] TechJack Solutions. "Silver Fox Deploys ValleyRAT via Fake OpenAI Model."³⁴
- [81] Safedep.io. "Malicious fairwords npm Credential Worm."¹³
- [98] Kiteworks. "IBM X-Force 2026 AI Data Governance."¹⁹
- [99] BreachSense. "Infostealer Malware Trends 2025."¹⁸
- [100] Irish Tech News. "IBM X-Force Report Finds 84% Increase in Phishing Emails."²⁰
- [101] IBM 2026 X-Force Threat Index. "AI-Driven Attacks are Escalating."⁷
- [102] Elastic Security Labs. "EDDIESTEALER Rust-based Infostealer."¹⁵
- [103] SecurityBrief AU. "EDDIESTEALER Rust Malware Mimics CAPTCHA."²³
- [104] SC Media. "ClickFix spread novel Rust-based infostealer."²⁴
- [105] The Hacker News. "EDDIESTEALER Bypasses Chrome App-Bound Encryption."²⁵
- [106] Cyware. "Weekly Threat Intelligence May 2025."²⁶
- [107] Adili Africa. "Infostealers CTI Report July 2025."²⁷
- [109] Infostealers.com. "Polyfill.io Mastermind: Forensic Evidence Links DPRK."³³
- [111] Cyble. "The Growing Threat of ChatGPT-Based Phishing."²¹
- [112] Cyberint. "Strategic Cyber Threats in the U.S. 2023."²²

Works cited

1. The Silent Epidemic: Infostealers and the Evolution of Cybercrime in 2025 - Ankura.com,
<https://ankura.com/insights/the-silent-epidemic-infostealers-and-the-evolution-of-cybercrime-in-2025>
2. Microsoft Digital Defense Report 2025 – Safeguarding Trust in the AI Era,
<https://cdn-dynmedia-1.microsoft.com/is/content/microsoftcorp/microsoft/msc/documents/presentations/CSR/Microsoft-Digital-Defense-Report-2025.pdf>
3. Infostealers stole 1.8B credentials in 2025: How to defeat them - Vectra AI,
<https://www.vectra.ai/topics/infostealers>
4. Behind the Curtain: How Lumma Affiliates Operate - Recorded Future,
<https://www.recordedfuture.com/research/behind-the-curtain-how-lumma-affiliates-operate>
5. LLMjacking - How Attackers Hijack AI Using Compromised NHIs,
https://23579664.fs1.hubspotusercontent-na1.net/hubfs/23579664/Assets/LLMjacking-Report-entro-labs.pdf?_hstc=39465980.7d7f0b426db9903468fcc59a012cb8b0.1736334448460.1744236768331.1744240812642.14&_hssc=39465980.3.1744240812642&hsCtaTracking=82563f08-c175-41ec-a5e2-bed54cb3b152%7C5efff153-f37b-4d3b-a928-daffe0f15ae7
6. LLMjacking: How Attackers Hijack AI Using Compromised NHIs,
<https://nhimg.org/llmjacking-how-attackers-hijack-ai-using-compromised-nhis>
7. IBM 2026 X-Force Threat Index: AI-Driven Attacks are Escalating as Basic Security Gaps Leave Enterprises Exposed - PR Newswire,
<https://www.prnewswire.com/news-releases/ibm-2026-x-force-threat-index-ai-driven-attacks-are-escalating-as-basic-security-gaps-leave-enterprises-exposed-302696274.html>
8. LLMjacking — How AI API Key Theft Works and How to Prevent It - DEV Community,
<https://dev.to/kuboidsecurelayer/llmjacking-how-ai-api-key-theft-works-and-how-to-prevent-it-45li>
9. LLM Security in Cloud-Native Architectures: A Comprehensive Survey of Attacks, Defenses, and Operational Challenges - TechRxiv,
<https://www.techrxiv.org/doi/pdf/10.36227/techrxiv.177130593.35890269/v1>
10. Lumma Stealer: Breaking down the delivery techniques and capabilities of a prolific infostealer | Microsoft Security Blog,
<https://www.microsoft.com/en-us/security/blog/2025/05/21/lumma-stealer-breaking-down-the-delivery-techniques-and-capabilities-of-a-prolific-infostealer/>
11. 2025 Cloud Threat Hunting and Defense Landscape - Recorded Future,
<https://www.recordedfuture.com/research/2025-cloud-threat-hunting-defense-landscape>
12. Technical Analysis of the LAMEHUG Campaign (APT28) | by SIMKRA | T3CH - Medium,

- <https://medium.com/h7w/technical-analysis-of-the-lamehug-campaign-apt28-4c99b147518c>
13. @fairwords npm Packages Hit by Credential Worm - Real-time Open Source Software Supply Chain Security - SafeDep,
<https://safedep.io/malicious-fairwords-npm-credential-worm/>
 14. Unmasking Lumma Stealer: Analyzing Deceptive Tactics with Fake CAPTCHA - Qualys Blog,
<https://blog.qualys.com/vulnerabilities-threat-research/2024/10/20/unmasking-lumma-stealer-analyzing-deceptive-tactics-with-fake-captcha>
 15. Chasing Eddies: New Rust-based InfoStealer used in CAPTCHA campaigns - Elastic, <https://www.elastic.co/security-labs/eddiestealer>
 16. Brand Hijack in Cybercrime: Who Is Pretending to Be ShinyHunters? | Hive Pro,
<https://hivepro.com/threat-advisory/brand-hijack-in-cybercrime-who-is-pretending-to-be-shinyhunters/>
 17. Cloud Service Hijacking | Red Canary Threat Detection Report,
<https://redcanary.com/threat-detection-report/techniques/cloud-service-hijacking/>
 18. Infostealer Malware: How It Works and How to Protect Your Organization - Breachsense, <https://www.breachsense.com/blog/infostealer-malware/>
 19. IBM X-Force 2026: AI Data Governance Gaps Attackers Exploit - Kiteworks,
<https://www.kiteworks.com/cybersecurity-risk-management/ibm-xforce-2026-ai-data-governance/>
 20. IBM X-Force Report Finds 84% Increase in Phishing Emails Delivering Infostealers YoY, <https://irishtechnews.ie/ibm-x-force-report-increase-in-phishing-emails/>
 21. The Growing Threat of ChatGPT-Based Phishing Attacks: What You Need to Know - Cyble,
<https://cyble.com/blog/the-growing-threat-of-chatgpt-based-phishing-attacks/>
 22. The U.S. Threat Landscape in 2023 - Cyberint,
<https://cyberint.com/blog/research/the-us-threat-landscape-in-2023/>
 23. EDDIESTEALER Rust malware mimics CAPTCHA to steal credentials,
<https://securitybrief.com.au/story/eddiestealer-rust-malware-mimics-captcha-to-steal-credentials>
 24. ClickFix used to spread novel Rust-based infostealer | news | SC Media,
<https://www.scworld.com/news/clickfix-used-to-spread-novel-rust-based-infostealer>
 25. New EDDIESTEALER Malware Bypasses Chrome's App-Bound Encryption to Steal Browser Data - The Hacker News,
<https://thehackernews.com/2025/05/eddiestealer-malware-uses-clickfix.html>
 26. Cyware Weekly Threat Intelligence, May 26–30, 2025,
<https://www.cyware.com/resources/threat-briefings/weekly-threat-briefing/cyware-weekly-threat-intelligence-may-26-30-2025>
 27. Cyber Threat Intelligence (CTI) Report Information Stealers July 2025 - Adili Group,

- <https://adili.africa/wp-content/uploads/2025/07/Infostealers-CTI-report.pdf>
28. A Deep Dive Into Malicious Direct Syscall Detection - Palo Alto Networks Blog,
<https://www.paloaltonetworks.com/blog/security-operations/a-deep-dive-into-malicious-direct-syscall-detection/>
 29. Incident 1220: LAMEHUG Malware Reportedly Integrates Large Language Model for Real-Time Command Generation in a Purported APT28-Linked Cyberattack,
<https://incidentdatabase.ai/cite/1220/>
 30. What Is an Infostealer? How Credential-Stealing Malware Works - SentinelOne,
<https://www.sentinelone.com/cybersecurity-101/cybersecurity/infostealer/>
 31. Disrupting a global cybercrime network abusing generative AI - Microsoft On the Issues,
<https://blogs.microsoft.com/on-the-issues/2025/02/27/disrupting-cybercrime-abusing-gen-ai/>
 32. Microsoft targets AI deepfake cybercrime network in lawsuit - TechTarget,
<https://www.techtarget.com/searchsecurity/news/366619781/Microsoft-targets-AI-deepfake-cybercrime-network-in-lawsuit>
 33. How One Infostealer Infection Solved a Global Supply Chain Mystery and Unmasked DPRK Spies in U.S. Crypto,
<https://www.infostealers.com/article/how-one-infostealer-infection-solved-a-global-supply-chain-mystery-and-unmasked-dprk-spies-in-u-s-crypto/>
 34. Silver Fox Deploys ValleyRAT via Fake OpenAI Model on Hugging Face, 244K Downloads in 18 Hours - Tech Jacks Solutions,
<https://techjacksolutions.com/scc-intel/silver-fox-deploys-valleyrat-via-fake-open-ai-model-on-hugging-face-244k-downloads-in-18-hours/>
 35. Research - HiddenLayer, <https://www.hiddenlayer.com/innovation-hub/research>
 36. AI API Key Abuse and Runaway Compute Costs | PointGuard AI,
<https://www.pointguardai.com/blog/when-a-stolen-ai-api-key-becomes-an-82-000-problem>
 37. We are facing possible bankruptcy after unauthorized Gemini API usage reached about \$128k even after we paused the API, and Google denied our adjustment request. (Case #68928270) : r/googlecloud - Reddit,
https://www.reddit.com/r/googlecloud/comments/1rv3xr9/we_are_facing_possible_bankruptcy_after/
 38. The API Weak Spot: Study Shows AI Is Compounding Security Pressures - Akamai,
<https://www.akamai.com/blog/security/api-weak-spot-study-ai-compounding-security-pressures>
 39. AI LLM Hijack Breach - Non-Human Identity Management Group,
<https://nhimg.org/ai-llm-hijack-breach>
 40. The Ultimate Guide To Non-Human Identities,
<https://nhimg.org/the-ultimate-guide-to-non-human-identities>
 41. Category: Supply Chain Vulnerabilities - Nocturnalknight's Lair,
<https://nocturnalknight.co/category/information-security/supply-chain-vulnerabilities/>

42. Everything You Need to Know About Securing Generative AI Workloads and Large Language Models (LLMs) - Qualys,
<https://www.qualys.com/faq-gen-ai-and-llm>
43. AI Agents' Most Downloaded Skill Is Discovered to Be an Infostealer,
<https://www.infostealers.com/article/ai-agents-most-downloaded-skill-is-discovered-to-be-an-infostealer/>